



RouteOne, LLC

SOC 2 Type 2 Report

Report on the Dealer Management System throughout the period October 1, 2024 to September 30, 2025

Contents

Section 1.	Independent Service Auditor's Report	2
Section 2.	RouteOne, LLC Management's Assertion	6
Section 3.	RouteOne, LLC's Description of its Dealer Management System	
	A. Company Overview	8
	B. Scope of Report	9
	C. Principal Service Commitments and System Requirements	9
	D. Subservice Organizations	10
	E. Entity Level Management Processes	12
	F. Components of the System	15
	G. Applicable Trust Service Criteria and Related Controls	20
	H. Complementary User Entity Controls	20
	I. User Entity Responsibilities	20
Section 4.	Trust Services Criteria and RouteOne, LLC's Description of Related Controls and Service Auditor's Description of Tests of Controls and Results	22
Section 5.	Other Information Provided by Management of RouteOne, LLC	68

Independent Service Auditor's Report

To Management
RouteOne, LLC

Scope

We have examined management of RouteOne, LLC's (RouteOne) accompanying description of its Dealer Management System titled "RouteOne, LLC's Description of its Dealer Management System" throughout the period October 1, 2024 to September 30, 2025 (the "description") based on the criteria for a description of a service organization's system in DC Section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report* (AICPA, *Description Criteria*) (the "description criteria"), and the suitability of the design and operating effectiveness of RouteOne's controls stated in the description throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that RouteOne's service commitments and system requirements were achieved based on the trust services criteria for security, availability, confidentiality, and privacy (the "applicable trust services criteria") set forth in TSP Section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

The information included in Section 5, "Other Information Provided by Management of RouteOne, LLC," is presented by management of RouteOne to provide additional information and is not a part of RouteOne's description. Information about RouteOne's responses to deviations has not been subjected to the procedures applied in the examination of the description and of the suitability of the design and operating effectiveness of controls to achieve RouteOne's service commitments and system requirements based on the applicable trust services criteria, and, accordingly, we express no opinion on it.

RouteOne uses subservice organizations for web hosting of the production system and data center hosting services. A list of these subservice organizations is provided in the description of the system. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at RouteOne, to achieve RouteOne's service commitments and system requirements based on the applicable trust services criteria. The description presents RouteOne's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of RouteOne's controls. The description does not disclose the actual controls at the subservice organizations. Our examination did not include the services provided by the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at RouteOne, to achieve RouteOne's service commitments and system requirements based on the applicable trust services criteria. The description presents RouteOne's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of RouteOne's controls. Our examination did not include such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

Service Organization's Responsibilities

RouteOne is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that RouteOne's service commitments and system requirements were achieved. RouteOne management has provided the accompanying assertion titled "RouteOne Management's Assertion" (the "assertion") about the description and the suitability of design and operating effectiveness of controls stated therein. RouteOne management is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria; stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of the design and operating effectiveness of the controls stated in the description based on our examination.

Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants (AICPA). Those standards require that we plan and perform the examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operating effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion. An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of the service organization's controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements
- Assessing the risks that the description is not presented in accordance with the description criteria and that the controls were not suitably designed and operating effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of those controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Service Auditor's Independence and Quality Control

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature and inherent limitations, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of the controls is subject to the risks that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls tested and the nature, timing, and results of our tests are presented in Section 4 of this report. The scope of our engagement did not include tests to determine whether trust services categories, related criteria, and control activities not listed in Section 4 were achieved; accordingly, we express no opinion on the achievement of controls not included in Section 4.

Opinion

In our opinion, in all material respects:

- The description presents RouteOne's Dealer Management System that was designed and implemented throughout the period October 1, 2024 to September 30, 2025 in accordance with the description criteria.
- The controls stated in the description were suitably designed throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that RouteOne's service commitments and system requirements would be achieved based on the applicable trust services criteria if its controls operated effectively throughout the period October 1, 2024 to September 30, 2025 and if the subservice organizations and user entities applied the complementary controls assumed in the design of RouteOne's controls throughout the period October 1, 2024 to September 30, 2025.
- The controls stated in the description operated effectively throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that RouteOne's service commitments and system requirements were achieved based on the applicable trust services criteria if complementary subservice organization controls and complementary user entity controls assumed in the design of RouteOne's controls operated effectively throughout the period October 1, 2024 to September 30, 2025.

Emphasis of Matter

As noted in management's description, there was no misuse, unauthorized disclosures, or disputes of personal information during the period October 1, 2024 to September 30, 2025. Therefore, we did not test the operating effectiveness of those specific controls in order to achieve the following service commitment:

- Data Privacy, "RouteOne commits to handling data subjects' information in accordance with their privacy policies."

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4 of this report, is intended solely for the information and use of RouteOne; user entities of RouteOne's Dealer Management System throughout the period October 1, 2024 to September 30, 2025; business partners of RouteOne subject to risks arising from interactions with the system; practitioners providing services to such user entities and business partners; prospective user entities; and business partners and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties
- Internal control and its limitations
- Complementary user entity controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements

To Management
RouteOne, LLC

- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.

Plante & Moreau, PLLC

November 12, 2025



31500 Northwestern Hwy, Ste 300
Farmington Hills, MI 48334

November 12, 2025

Plante & Moran, PLLC

To Service Auditors:

We have prepared the accompanying description of RouteOne, LLC's ("RouteOne") Dealer Management System titled "RouteOne LLC's Description of its Dealer Management System" throughout the period October 1, 2024 to September 30, 2025 (description) based on the criteria DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report* (AICPA, *Description Criteria*) (description criteria). The description is intended to provide report users with information about RouteOne's Dealer Management system that may be useful when assessing the risks arising from interactions with the Dealer Management system, particularly information about system controls that RouteOne has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, confidentiality, and privacy (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

RouteOne uses subservice organizations for web hosting of the production system and data center hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at RouteOne, to achieve RouteOne's service commitments and system requirements, based on the applicable trust services criteria. The description presents RouteOne's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of RouteOne's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at RouteOne, to achieve RouteOne's service commitments and system requirements, based on the applicable trust services criteria. The description presents RouteOne's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of RouteOne's controls.

We confirm, to the best of our knowledge and belief, that:

- a. the description presents RouteOne's Dealer Management system that was designed and implemented throughout the period October 1, 2024 to September 30, 2025 in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period October 1, 2024 to September 30, 2025 provide reasonable assurance that RouteOne's service commitments and system requirements would be achieved based on the applicable trust



31500 Northwestern Hwy, Ste 300
Farmington Hills, MI 48334

services criteria, if its controls operated effectively throughout that period, and if subservice organizations and user entities applied the complementary controls assumed in the design of RouteOne's controls throughout that period.

- c. The controls stated in the description operated effectively throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that RouteOne's service commitments and system requirements, would be achieved based on the applicable trust services criteria and if complementary subservice organization controls and complementary user entity controls assumed in the design of RouteOne's controls operated effectively throughout that period.

As noted in management's description, there were no misuse, unauthorized disclosures, or disputes of personal information during the period from October 1, 2024 to September 30, 2025. Therefore, we did not test the operating effectiveness of those specific controls in order to achieve the following service commitment:

- Data Privacy, "RouteOne commits to handling data subjects' information in accordance with their privacy policies."

Very truly yours,

A handwritten signature in black ink that reads "Daniel Doman".

B50C1DBC4FBB4C5...

Daniel J. Doman, Chief Legal and Privacy Officer

SECTION 3. ROUTEONE, LLC'S DESCRIPTION OF ITS DEALER MANAGEMENT SYSTEM

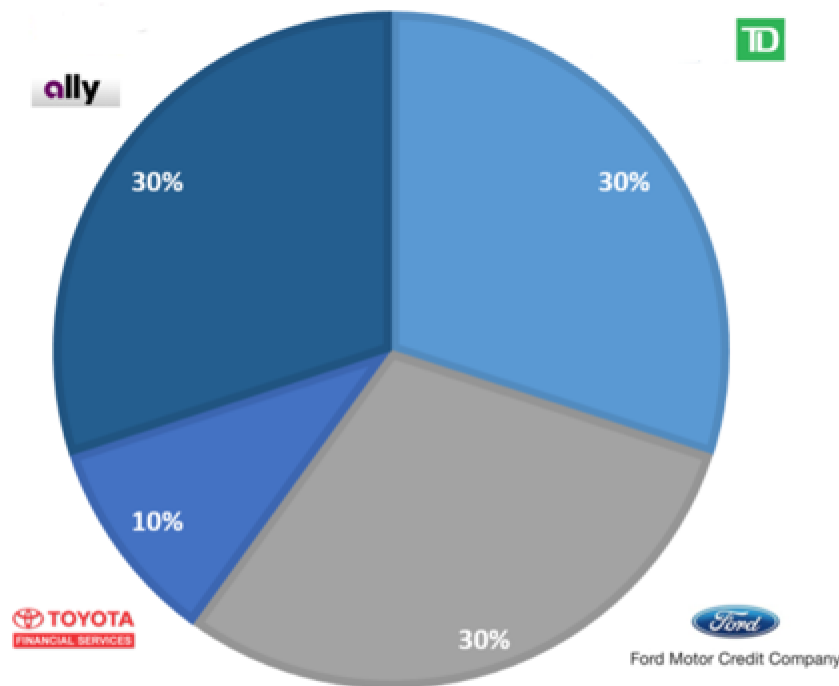
A. Company Overview

RouteOne, LLC's ("RouteOne" or "Company") Dealer Management System is a web-based system established in 2002, to deliver improved efficiencies for credit aggregation services via its RouteOne application and ancillary processes such as compliance for automobile dealers, its customers, and participating finance institutions. These services were originally chartered by the captive finance arms of Stellantis North America, Ford Motor Company, General Motors, and Toyota, in response to the needs of their respective dealerships.

The Dealer Management System was piloted in 2003 and introduced to dealers nationwide in early 2004. The majority of the nation's 21,500 franchised dealerships are enrolled and actively processing applications through the system. Operations in Canada have been fully established for Ford Motor Credit Company as well as Canadian independent finance sources and dealerships. The core RouteOne platform is available to all franchised and independent automotive dealerships at no cost. RouteOne is an open finance source platform intended to serve the dealer community as a one-stop shop for credit and compliance needs.

The RouteOne vision is to be the Dealer Management System of choice for dealers, while fairly presenting the value equation of participating finance sources.

TD Bank, Ford Motor Credit Company, and Ally Financial each hold a 30 percent equity interest in RouteOne, with Toyota Financial Services holding a 10 percent equity interest. RouteOne is governed by a Board of Directors, of which the founding owners are members.



B. Scope of Report

The scope of this report is limited to RouteOne's Dealer Management System throughout the period October 1, 2024 to September 30, 2025 based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, Description Criteria) (description criteria), and the controls to achieve RouteOne's service commitments and system requirements based on the trust services criteria relevant to security, availability, confidentiality, and privacy (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, Trust Services Criteria).

The scope of the report is limited to the Dealer Management System in the United States. The physical location in-scope is Farmington Hills, Michigan.

The Dealer Management System application includes the following:

- Credit Application Processing for Lease and Retail
- eContracting
- Compliance Tools
- Credit Bureau Access
- Reporting Suite
- The RouteOne App Mobile Devices

Significant Changes in the System and Controls

There were no significant changes in the system or controls during the period October 1, 2024 to September 30, 2025.

Subsequent Events

Management is not aware of any relevant events that occurred subsequent to the end of the reporting period through the date of the service auditor's report that would have a significant effect on management's assertion.

C. Principal Service Commitments and System Requirements

RouteOne makes service commitments to its customers for the following:

- **Security of Data** - RouteOne commits to securing client data that is processed within the Dealer Management System.
- **Availability of Data** - RouteOne commits to making client data available.
- **Confidentiality of Data** - RouteOne commits to ensuring confidentiality of data.
- **Data privacy** - RouteOne commits to handling data subjects' information in accordance with their privacy policies.

RouteOne has established operational requirements that support the achievement of security commitments, as well as relevant laws and regulations. These operational requirements are communicated through RouteOne's policies and procedures:

- **Encryption** - BitLocker encryption is enabled on all laptops and workstations and a unique BitLocker identifier is required to gain access to machines and enforced through Intune. RSA 2048-bit SSL encryption is used for the browser-based RouteOne application, and 256-bit encryption is used for the database.

- **User Access Reviews** - A monthly user access review is performed by the Governance, Risk, and Compliance Manager to ensure access levels to the production environment and the network are appropriate and only authorized individuals have access.
- **Capacity Monitoring** - Internal control monitoring results, including the use of system components to monitor assets and performance tools, are monitored quarterly by the Governance, Risk, and Compliance (GRC) Team.
- **Data Retention and Disposal** - A Document Retention Form sign off review is performed by the Governance, Risk, and Compliance (GRC) Team on an annual basis to ensure compliance with the retention schedule. Production data is retained according to the Data Purge Policy. Oracle purge jobs are configured to run on a daily basis.
- **Privacy Statement** - The Privacy Statement defines the methods for collecting personal information from data subjects through third parties. The Privacy Statement is communicated to potential data subjects through RouteOne's public-facing website.

D. Subservice Organizations

Management of RouteOne assumed, in the design of RouteOne's Dealer Management System that certain controls at subservice organizations are necessary, in combination with controls at RouteOne, to provide reasonable assurance that RouteOne's service commitments and system requirements would be achieved. These complementary subservice organization controls and the related trust services criteria are described below. Subservice organizations are responsible for implementing such controls.

The following are the subservice organizations used by RouteOne, services provided by them, and the trust services criteria that are applicable to the services that they provide:

- **NTT** - Managed services for the web hosting of the production system and data center hosting services
- **Switch** - Down-stream data center hosting services in conjunction with NTT

Applicable Trust Services Criteria	Expected Controls to be Implemented by the Subservice Organizations
Common Criteria 6.1: The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Secure storage and encryption controls on the production environment.
Common Criteria 6.2: Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Logical access restrictions are in place for the production environment.
Common Criteria 6.4: The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.	All entrances to the building and data center are locked and access is restricted. A user access review of individuals with access to data center is performed.

Applicable Trust Services Criteria	Expected Controls to be Implemented by the Subservice Organizations
Common Criteria 6.5: The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.	Procedures for the secure disposal of servers are followed.
Common Criteria 6.6: The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	Monitoring and reviewing of unauthorized attempts to access the production environment is performed.
Common Criteria 6.8: The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Production servers are protected with antivirus software and periodic antivirus reviews are performed. Patches are installed on a quarterly basis.
Common Criteria 7.2: The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Monitoring and reviewing of unauthorized attempts to access the production environment is performed.
Availability Criteria 1.1: The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.	Critical infrastructure components have been reviewed for criticality classification and have been assigned a minimum level of redundancy. Processing capacity is monitored on a daily basis.

Applicable Trust Services Criteria	Expected Controls to be Implemented by the Subservice Organizations
Availability Criteria 1.2: The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data back-up processes, and recovery infrastructure to meet its objectives.	The following controls are implemented within the data center: •Equipment is maintained on racks within data center. •Smoke and fire detection systems are in place. •Fire suppression system is in place. •Fire extinguishers are in place. •Dedicated air conditioning units are in place. •Uninterruptible power supply is in place and tested at least quarterly. •Generators are in place and tested at least quarterly. Environmental monitoring software is utilized and alerting is in place. Environmental protections above receive maintenance on at least an annual basis. Weekly full system and daily incremental backups are performed. Backups are monitored for failure.
Availability Criteria 1.3: The entity tests recovery plan procedures supporting system recovery to meet its objectives.	Recovery procedures are in place. The disaster recovery plan is tested on an annual basis.

E. Entity Level Management Processes

Control Environment

All RouteOne operations are under the direction of its Chief Executive Officer (CEO) and Board of Directors. The Board of Directors has the overall responsibility and accountability for RouteOne's system controls. The Board of Directors is independent from management. In addition, the RouteOne Governance, Risk, and Compliance Manager executes an internal audit program, verifying that processes and controls are in place and being executed as designed. Day-to-day business is managed by the RouteOne executive team and their direct reports, including the CEO, Chief Legal and Privacy Officer (CLPO), Chief Financial Officer (CFO), and Chief Information Officer (CIO).

RouteOne's Employee Handbook sets expectations for integrity and ethical behavior of employees. The Employee Handbook also contains RouteOne's conduct standards, ethics policy, and statement of confidentiality and privacy practices. Employees are required to acknowledge the company's Employee Handbook within 30 days of hire. An organizational chart is in place, which defines structures, authorities, reporting lines and responsibility to meet business objectives. Human Resources documents and maintains the organizational chart. with authorization and oversight from the Compensation Committee, which is a subset of the Board of Directors.

The qualifications of prospective candidates and their ability to perform job responsibilities are evaluated by HR or the hiring manager during the hiring process. Background checks are completed prior to hire. Once an offer is extended to an US employee or contractor, RouteOne initiates the background check. Contracting companies are responsible for performing all background checks and drug screenings for individuals that work for them.

Employees and contractors attend new hire security awareness training and review the Information Security Policies within 30 days of hire. Security awareness and policy review training is held annually. Employees and contractors are required to attend. The Comprehensive Information Security Policy (CISP) is included in security awareness training. For employees and contractors with the ability to write code, specialized training is required annually.

A performance appraisal is completed by each employee's manager annually. Each employee and contractor is required to sign a confidentiality agreement within seven days of hire, which includes privacy practices.

Risk Assessment

The Risk Management Framework documents the system objectives and procedures for managing the Risk Assessment process. Additionally, the Risk Management Framework documents the following processes: identification of assets, threats, impact, probability, risk rating, and risk mitigation. The Risk Assessment is performed annually by the Manager, Governance, Risk, and Compliance and reviewed by members of IT Leadership, GRC Team, and the Legal Team. The Risk Assessment documents the risk, risk category, rating, control activities, control type (preventative, detective, automatic, manual), control frequency, and control monitoring. Risks related to segregation of duties, fraud, vendors, technological and environmental changes, and corrective actions are also documented.

As an input of the Risk Assessment, management identifies key systems and system processes to support the in-scope services provided. Relevance, completeness, and accuracy of sources of information necessary to evaluate the operating effectiveness of internal controls and perform internal control activities are included in the Risk Assessment. The controls documented are tied to the risks they have been implemented to mitigate.

Control Activities

Policies, Procedures, and Standards

Using the NIST Security Baseline objectives as a starting point, RouteOne has defined a comprehensive set of policies and procedures. These policies and procedures are intended to protect the interests of those relying on the information within the RouteOne Dealer Management System and the systems that deliver this information. RouteOne, therefore, has a proven and accepted set of control objectives that help ensure RouteOne will protect against harm from threats such as: loss of data, inaccessibility to data or systems, unauthorized access to data or systems, alteration of information, wrongful disclosure, omissions, fraud, accidents, and intentional damage.

RouteOne ensures a robust and secure environment by implementing a layered series of safeguards including physical security measures, background checks, user identifiers, passwords, and firewalls.

The regulatory requirements defined in the Gramm-Leach-Bliley Act (GLBA) are also considered in the definition of RouteOne information security policies and procedures. The combination of these GLBA requirements, other regulatory requirements, and the NIST control objectives were used to define RouteOne's System and Organization Controls (SOC) control subset.

An Information Technology (IT) Strategy Document is developed by the IT Management team and is based on RouteOne's mission, goals, and business objectives. Goals related strategic tasks are defined to accommodate the objectives in the current year and in the future.

The CISP is available on the intranet to RouteOne employees and contractors and includes policies and procedures regarding:

- Appropriate use
- Security awareness training
- Access rights
- Physical control
- Confidentiality
- Business continuity
- Security response
- Data disposal and change management
- Physical hardware safeguards.

The CISP is reviewed and updated by the Governance, Risk, and Compliance (GRC) Team, including the CLPO, at least annually.

Dealers and finance source users that access the RouteOne application must accept the Application Use Policy online before they are able to utilize the system. The policy is displayed on the login page and approval is implied upon login.

To align RouteOne's business strategies and goals with operating performance, management is committed to maintaining effective communications with all personnel. All management staff participate in weekly meetings to discuss the status of current user processing, organizational structure, or other concerns and interests. Issues or suggestions identified by personnel and Service Desk operations are readily brought to the attention of the employee's manager to be addressed and resolved.

Information and Communication

RouteOne utilizes various methods of communication to ensure all employees understand their roles and responsibilities with respect to controls and to help ensure that significant events are communicated in a timely manner. Policy and procedure documents addressing security, availability, confidentiality, and privacy commitments and significant processes are available on the intranet for internal users. An organizational chart is in place and available on the intranet for all internal users. These methods include orientation and training programs for newly hired employees, annual training sessions, and the use of electronic messages to communicate more time-sensitive messages and information. All employees are trained annually on the organization's HR, Security, and Legal processes. Job descriptions define roles and responsibilities for each position, including the Manager, Governance, Risk, and Compliance who has overall responsibility for all compliance related activities.

RouteOne has implemented an electronic Policy and Procedure Management System to make all policies, procedures, and standards readily available to employees and contractors. In order to ensure access to the current versions of all the controls that have been instituted, this system is accessible by all authorized users on the RouteOne corporate network. This increases awareness, compliance, and feedback on all aspect of controls.

Each policy and procedure is subject to executive management review, peer review, or both, prior to implementation. It is a critical strategy to maintain documents that properly state the controls RouteOne operationally enforces; this strategy enables efficiency, consistency, and compliance. The CLPO communicates results of third-party assessments, internal control vulnerabilities, and changes that impact the environment, technology and regulation to the Board of Directors on a quarterly basis.

The End User Communication Procedure defines the process for informing users of changes, including changes to security, availability, confidentiality, and privacy commitments or practices. System changes that may affect security, availability, confidentiality, and privacy are communicated to internal users via release notes and the development status report, which are updated in real time. System changes that may affect system security, availability, confidentiality, and privacy are communicated to clients through an announcement on the external-facing website. The RouteOne external-facing website instructs external users on how to report incidents, concerns and complaints.

Additionally, RouteOne maintains contracts with dealers, finance sources, and other third parties exposed to confidential information. New Dealers must sign a Dealer Participation Agreement including, but not limited to, RouteOne data security and confidentiality policies. Included within the Agreement is a Dealer Use Policy describing acceptable use of the RouteOne application. New Finance Sources must sign a Finance Source Access and Services Agreement that contains (among other items) confidentiality clauses. In addition to the Agreement, finance sources also receive a Finance Source Use Policy that contains policies regarding acceptable use of the RouteOne application.

A Master Services Agreement or contract is used between all other third parties exposed to confidential information through RouteOne. The Agreement contains terms regarding security, confidentiality, and availability.

Monitoring

RouteOne management and supervisory personnel monitor the quality of internal controls performance as a normal part of their activities. The Internal Audit Procedure documents the scope and frequency of internal control monitoring.

The GRC Team reviews the NTT and Switch SOC reports on an annual basis to determine controls related to physical & environmental security, availability & recovery, on-site privacy & compliance, and security levels and monitoring of the production servers are in place and that system requirements commitments are met.

Microsoft Defender alerts are submitted to the Security and GRC Teams if new or unknown devices connect to the network. Alerts are responded to by the Security and GRC Teams in real time within the Microsoft Defender Dashboard.

Patches to the production servers by NTT are initiated by a Web Hosting Change Management ticket in the RouteOne system. High and medium risk patches are tested, if applicable, and approved by the Senior Director of IT Operations or designee, on behalf of the CIO, prior to implementation in production.

F. Components of the System

Infrastructure

The hosting of the RouteOne production environment is housed at the Switch data center through contract with NTT. RouteOne employs dual production sites housed within third-party facilities in Las Vegas, Nevada. The RouteOne disaster recovery site is located in Plymouth, MI. The hosting environment consists of hardware and software components that support the in-scope services in a data center owned and operated by a third-party.

Software

The following is the primary application in-scope:

Application	Function
Dealer Management System	A web-based dealership software platform that offers a variety of tools to help manage sales and financing processes.

The following tools are used to support the Dealer Management System:

Application	Function
Active Directory	Directory-based access control
Duo Mobile and Microsoft Authenticator	Multifactor authentication
JIRA/CloudLink	Ticketing system
Splunk/Qradar	Log collection and SIEM

Application	Function
Employee Management System (EMS)	HR management system
Windows Defender/CrowdStrike	Malware, antivirus monitoring, event logging, and network monitoring
BitLocker	Device encryption
ADP	HR software
Intune	Device management software
Zabbix	Capacity monitoring
Grafana	Database analytics and monitoring

People

The following groups support the Dealer Management System:

- Board of Directors and the CEO - Responsible for the oversight of internal controls.
- Governance, Risk, and Compliance (GRC) Team - Responsible for developing, implementing and executing the internal audit program.
- Product Development Team - Responsible for developing and maintaining the Dealer Management System.
- Business Operations Team - Responsible for providing support to the Dealer Management System.
- Sales and Marketing Team - Responsible for the growth of RouteOne.
- IT Operations Team - Responsible for the functionality of the network and RouteOne Application.
- Security Team - Responsible for the security and monitoring of the network and RouteOne Application.

Data

Dealerships and finance sources are the data controllers and determine the purpose of the data collected. RouteOne processes the data for its business-to-business transactions within the Dealer Management System. Data subjects are consumers utilizing dealership websites and applications. RouteOne does not collect personal information directly from or communicate with data subjects, this is the responsibility of the dealers. Dealers are responsible for providing the individuals with access to their information and notifying RouteOne of any data changes. RouteOne does not share personal information data with third parties outside of contractual agreements for purposes of providing the dealership management service.

Procedures

Physical Security

Visitors are required to sign the visitor log. The main entrance and ancillary entrance doors to the RouteOne building suite are locked at all times and are equipped with proximity badges. The entrances to the server room and the external door are locked at all times and a proximity badge is required for entry. A video surveillance system monitors the activity inside the server room. The video footage is retained for at least 90 days.

Physical access to the building for new employees is approved via an automatic EMS email initiated by HR. Physical access to the building for terminated employees is removed by HR within one business day of termination.

Access to the server room is restricted to authorized individuals on the GRC, Legal, Facilities, CIO, HR, and IT Operations Teams. Server room access logs are reviewed weekly by the GRC Team.

Logical Security

When hired, the HR or hiring manager approves new employees and contractors by entering their information into the Employee Management System (EMS). An automated email is generated from the EMS and is sent to IT to grant access to the network. Access to the production environment is approved by HR or the employee/contractor's manager prior to provisioning. User access is granted based on the job needs of the specific user. Access modifications for employees who transfer departments are documented by HR personnel via email and approval is required by the employee's manager. HR sends a notification email to the Network Administrator for all employee or contractor terminations. Access is removed or disabled from the network and production by the Network Administrator within one business day of termination. A monthly user access review is performed by the GRC Team to ensure access levels to the production databases and the network are appropriate and only authorized individuals have access.

A separation of duties policy is in place and reviewed by the CLPO, Director-level counsel, and the Chief Information Officer annually. A matrix documents separation of duties between roles. The matrix is reviewed annually by IT or the GRC Team. The review of the matrix includes a review of current roles' access rights.

Network authentication parameters include:

- minimum password length of 8 characters
- password history of 11 passwords
- invalid login attempts of 3 attempts
- lockout duration after invalid attempts reached of 15 minutes
- inactivity timeout of 15 minutes.

The in-scope application authentication parameters include:

- minimum password length of 8 characters
- expiration of 60 days
- password history of 5 passwords
- invalid login attempts of 3 attempts
- inactivity (session) timeout of 30 minutes.

Administrative-level access to the network is restricted to the IT Operations team. Administrative-level access to the production environment and databases is restricted to those that require access to perform their necessary job functions.

A VPN is in place for remote access to the network and multifactor authentication is required. RSA 2048-bit SSL encryption is used for the browser-based RouteOne application, and 256-bit encryption is used for the database. Messages sent both inbound/outbound are checked for digital signatures. Messages sent without a valid digital signature are not accepted by RouteOne and an exception log is generated for errors. These exceptions are also sent to the corresponding inbound/outbound error queue that is monitored by IT Operations and errors are resolved, as necessary.

A firewall is in place on the RouteOne network. Reports of the production environment firewall events are sent to members of IT Leadership and the GRC Team, who perform the monthly review upon receipt of the report from the service provider. Security Activity Review meetings with NTT occur on a bi-monthly basis. Remediation of firewall events and vulnerability scans are discussed with the Senior Director of IT Operations and members of the GRC Team. Monthly firewall configuration compliance audits are performed by a third-party on the corporate and production firewalls. Remediations of critical or high findings are resolved by RouteOne through the Change Management process upon receipt of the audit results.

Microsoft Defender antivirus is in place for corporate workstations and servers. Definition files are updated every 4 hours and weekly scanning is configured. Real-time scans are also enabled. Weekly antivirus reviews are performed by the Manager, Governance, Risk, and Compliance or the GRC Analyst.

BitLocker encryption is enabled on all laptops and workstations and a unique BitLocker identifier is required to gain access to machines and enforced through Intune. Write access to unencrypted removable drives is prohibited and enforced through Intune. A mobile device management system is in place for remote wipe capabilities. All mobile devices are required to be encrypted.

The Asset Tag Procedure documents the role of maintenance of asset inventory. An asset inventory is developed and maintained by the Accounting Department and Network Administrators.

System Monitoring & Maintenance

The Manager, Governance, Risk, and Compliance reviews the RouteOne network event logs (such as disabled users, invalid password attempts, etc.) weekly. Audits of unauthorized software on workstations and virtual machines are performed twice a month. Findings are reviewed and remediated by the Manager, Governance, Risk, and Compliance. Web application scans including the dealer management system are performed by a third-party annually. Findings are prioritized based on management's evaluation of risk and business impact. Medium and above findings are tracked for resolution via Service Desk Tickets.

The GRC Team receives alerts within the Defender dashboard when social security numbers are found in incoming and outgoing emails. The GRC Team then reviews the alerts and performs any responses or actions if necessary.

System Operations

The Security Incident Response Procedure (SIRP) addresses the process for identifying, reporting and responding to security, availability, confidentiality, and privacy events and/or incidents. The Network Procedure addresses monitoring and responding to security-related events.

The RouteOne external-facing website instructs external users on how to report incidents, concerns and complaints. Security incidents are tracked to resolution and a root cause analysis is performed by IT. The SIRP security incident tabletop walkthrough is performed by RouteOne IT Senior Management and with a third-party annually.

Reports of the vulnerability scans performed on the production environment by NTT are received and reviewed by the Senior Director of IT Operations, the Security Team, and the GRC Team monthly. Web application scans including the dealer management system are performed by a third-party annually. Findings are prioritized based on management's evaluation of risk and business impact. Medium and above findings are tracked for resolution via Service Desk Tickets.

System Development & Change Management

Change management is the controlled implementation of changes to any business, support, or technical component that may impact RouteOne's ability to provide service to its customers. RouteOne has implemented a Web Hosting Change Management (WHCM) process to govern activities to minimize the risk of a change adversely affecting the production environment. The overall goals of WHCM are to address:

- Planning and implementation
- Change review
- Allocation of priorities
- Change categorization
- Impact, risk, and resource assessment
- Change approval
- Change scheduling
- Emergency changes

Releases are deployed on a bi-weekly basis. A Release Risk Analysis spreadsheet is used for each release to track the planned changes that will be included in the release throughout the development process. Probability, impact severity, and an overall risk rating is developed for items within the following categories: Infrastructure, application layers, features, development and testing time, defects, and late changes. The Director of Applications Development, Director of Product Development, Senior Director of IT Operations, and the Canadian Product Director approve the Release Risk Analysis on the production deployment sign off form. Production validation testing is performed by the Test Team no later than five business days after a release has been moved to production.

Access to the staging environment is restricted to designated members of IT Operations and Production Development teams. Only test data is used in the development and test environments. The production, development, and test environments are segregated.

Risk Mitigation

Cyber insurance is in place and addresses cyber liability in the event of a cybersecurity breach.

The Vendor Risk Management Policy documents guidelines to analyze and manage risks associated with third-party relationships and also provides guidelines for selecting vendors. It defines the processes for analyzing risk of current vendors as well as monitoring controls, financial condition, quality of service, and the system requirements and responsibilities for risks associated with vendors. It also requires vendor risk assessment, due diligence analysis, and requirements for contracts with new security vendors to determine system commitments and system requirements are met. Vendor access is removed by IT upon termination.

Availability

The Business Continuity Plan (BCP) is tested annually by the GRC Team. The BCP includes recovery procedures from business disruption, event classifications, internal & external contact lists, cold site acknowledgement, and recovery tasks for each department. The Application Disaster Recovery Plan (DRP) for the production environment is prepared and tested annually by IT in conjunction with NTT. The plan includes: recovery teams, response and recovery process, server environment, and testing procedures and maintenance of plan.

Capacity monitoring of the production data is performed throughout the day by IT via Zabbix. Alerts are configured to be sent to the Network Administrators and resolved as necessary.

Confidentiality

The Data Classification policy documents access based on confidentiality, sensitivity levels, and enforcement. Retention/disposal standards are documented in the Document Retention Policy. Equipment and media are securely disposed by a third-party on an as needed basis. A certification of destruction is provided upon completion of all asset disposals.

Privacy

The Privacy Statement is the consumer-facing document that informs consumers on the collection, use, and disposal of consumer information.

The Privacy Policy is an internal RouteOne policy that informs employees on how RouteOne uses, collects, transfers, and disposes of consumer information.

Collection

The Privacy Statement on the RouteOne website defines the methods for collecting personal information from data subjects through third parties. Data is not collected directly from data subjects by RouteOne. The Privacy Statement is communicated to potential data subjects through RouteOne's public-facing website.

Use, Retention, and Disposal

The internal Privacy Policy defines the limitations related to the use of personal information collected based on the implicit consent of the data subjects. Production data is retained according to the Data Purge Policy. Oracle purge jobs of production data are configured to run on a daily basis, except when a release is moved to production. Locked shred bins are located throughout the office for corporate data disposal. A third-party securely disposes of the data and a certificate of destruction is documented. A Document Retention Attestation Report is acknowledged by the respective data owners and tracked to completion by the GRC Team on an annual basis to ensure compliance with the retention schedule.

Disclosure and Notification

The internal Privacy Policy states that RouteOne has agreements in place with third parties utilizing collected user information. The Privacy Policy addresses the requirement for an agreement to be in place requiring reasonable safeguards be implemented to comply with law, regulations, and contractual requirements. Authorized data disclosures from RouteOne to Dealers and Finance Sources are tracked by conversation IDs within the Grafana Dashboard. The dashboard is sent out by the IT Operations team. The database logs transactions of the conversation IDs, which are batched and purged on a daily basis in accordance with the retention requirements in the Data Purge Policy.

The Legal Department documents and performs corrective actions in response to misuse of personal information by a third-party. The Legal Department notifies affected users of a breach or incident in the case of a misuse or unauthorized disclosure of personal information.

Monitoring and Enforcement

The Business Operations Customer Communications document outlines the processes for handling customer inquiries, complaints, and disputes. RouteOne has implemented a dispute resolution documentation in order to effectively track each individual complaint along with the resolution and the communication to the RouteOne customers.

G. Applicable Trust Service Criteria and Related Controls

The Company's applicable trust services criteria, and the related controls designed to provide reasonable assurance that the service organization's service commitments and system requirements were achieved, are included in Section 4 of this report to eliminate the redundancy that would result from listing them in this section and repeating them in Section 4. Although the applicable trust services criteria and related controls are presented in Section 4, they are an integral part of the entity level management process and description of system used to provide services.

H. Complementary User Entity Controls

Management of RouteOne assumed, in the design of RouteOne's Dealer Management System that certain controls will be implemented by user entities, and those controls are necessary, in combination with controls at RouteOne, to provide reasonable assurance that RouteOne's service commitments and system requirements would be achieved. These complementary user entity controls and the related trust services criteria are described below. User entities are responsible for implementing such controls.

- User entities are responsible for ensuring users they add to their accounts within the RouteOne application are appropriate and passwords are secured. (Common Criteria 6.2, Common Criteria 6.3)
- User entities are responsible for notifying RouteOne in the event of actual or suspected unauthorized disclosures of personal information. (Privacy 6.3, Privacy 6.6)

I. User Entity Responsibilities

User entities may have responsibilities when using the system. Those responsibilities are necessary for the user entity to derive the intended benefits of using the services of RouteOne. User entity responsibilities are as follows:

-
- User entities are responsible for adherence to interface specifications and should be documented as a prerequisite to transacting with RouteOne as part of the contract phase and agreed upon prior to completion of any technical integration project.
 - User entities are responsible for signing agreements during enrollment, which require all Dealership clients to keep all dealer user IDs and passwords secure and users are prohibited from sharing accounts among its personnel.
 - User entities (dealers and finance sources) are responsible for use of the RouteOne application according to the terms of the dealer agreement and the RouteOne application use policies. Dealers and finance sources are further obligated to employ reasonable security measures to prevent internal and external breaches of its network security resulting in unauthorized access to the RouteOne application. Dealer personnel are required to take steps to prevent unauthorized access to their accounts by requiring all Dealer Users to log off of the RouteOne application when their workstation will be unattended. All passwords must be changed monthly and are required to be at least eight alphanumeric characters in length.
 - User entities are responsible for removing their own users' access. Requests to remove access to the RouteOne application for external users must come from the Dealers or finance sources. Dealers and finance sources are responsible for removing their own users' access.

SECTION 4. TRUST SERVICES CRITERIA AND ROUTEONE, LLC'S DESCRIPTION OF RELATED CONTROLS AND SERVICE AUDITOR'S DESCRIPTION OF TESTS OF CONTROLS AND RESULTS

This section presents the following information provided by RouteOne:

- The applicable trust services categories and criteria specified by the management of RouteOne.
- The controls established and specified by RouteOne to achieve the specified service commitments and system requirements based on the applicable trust services criteria.

Also included in this section is the following information provided by the service auditor:

- A description of the tests performed by the service auditor to determine whether the service organization's controls were operating with sufficient effectiveness to provide reasonable assurance that the specified service commitments and system requirements based on the applicable trust services criteria were achieved based on the applicable trust services criteria. The service auditor determined the nature, timing, and extent of the testing performed.
- The results of the service auditor's tests of controls.

The service auditor performed observation and inspection procedures as they relate to system-generated reports, queries, and listings to assess the accuracy and completeness of the information used in the service auditor's tests of controls.

A. Common Criteria

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
1.0	Common Criteria related to Control Environment		
1.1	The entity demonstrates a commitment to integrity and ethical values.		
	1. RouteOne's Employee Handbook sets expectations for integrity and ethical behavior of employees. The Employee Handbook also contains RouteOne's conduct standards, ethics policy, and statement of confidentiality and privacy practices.	Inspected the Employee Handbook to determine RouteOne's conduct standards, ethics policy, and statement of confidentiality and privacy practices, which set expectations for integrity and ethical behavior, are included.	No deviations noted.
	2. Employees are required to acknowledge the company's Employee Handbook within 30 days of hire.	Selected a sample of employees hired and inspected acknowledgements to determine Employee Handbook acknowledgments are completed within 30 days of hire.	No deviations noted.
	3. Each employee and contractor is required to sign a confidentiality agreement within seven days of hire, which includes privacy practices.	Selected a sample of employees and contractors hired and inspected signed confidentiality agreements, including privacy practices to determine they were signed no later than seven days after hire.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	4. The CISP is available on the intranet to RouteOne employees and contractors and includes policies and procedures regarding: •Appropriate use •Security awareness training •Access rights •Physical control •Confidentiality •Business continuity •Security response •Data disposal and change management •Physical hardware safeguards. The CISP is reviewed and updated by the Governance, Risk, and Compliance (GRC) Team, including the CLPO, at least annually.	Inspected the RouteOne intranet to determine the CISP is available to employees and contractors.	No deviations noted.
		Inspected the CISP to determine the aforementioned policies and procedures are documented.	No deviations noted.
		Inspected the CISP to determine it was reviewed by the GRC Team during the reporting period.	No deviations noted.
1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.		
	1. The Board of Directors has the overall responsibility and accountability for RouteOne's system controls. The Board of Directors is independent from management.	Inspected the Board of Directors meeting minutes to determine the Board of Directors has overall responsibility for system controls and are independent from management.	No deviations noted.
	2. The CLPO communicates results of third-party assessments, internal control vulnerabilities, and changes that impact the environment, technology and regulation to the Board of Directors on a quarterly basis.	Inspected the CLPO job description to determine the CLPO is responsible for communicating results of third-party assessments, internal control vulnerabilities, and changes that impact the environment, technology and regulation to the Board of Directors on a quarterly basis.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Selected a sample of quarters and inspected the Board of Directors meeting minutes to determine the results of third-party assessments, internal control vulnerabilities, and changes that impact the environment, technology and regulation are communicated by the CLPO.	No deviations noted.
1.3	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.		
	1. Human Resources documents and maintains the organizational chart.	Inspected the organizational chart to determine the organizational structure and reporting lines are defined and the organizational chart is maintained within the HR system.	No deviations noted.
	2. Job descriptions define roles and responsibilities for each position, including the Manager, Governance, Risk, and Compliance who has overall responsibility for all compliance related activities.	Selected a sample of employees, including the Governance Risk and Compliance Manager, and inspected job descriptions to determine job descriptions are defined for each employee selected and the Manager, Governance, Risk, and Compliance has overall responsibility for all compliance related activities.	No deviations noted.
1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.		
	1. A performance appraisal is completed by each employee's manager annually.	Selected a sample of employees and inspected performance appraisals to determine a performance appraisal was performed by the employee's manager during the reporting period.	No deviations noted.
	2. The qualifications of prospective candidates and their ability to perform job responsibilities are evaluated by HR or the hiring manager during the hiring process.	Selected a sample of employees hired and inspected qualification reviews to determine new employees are evaluated during the hiring process.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	3. Background checks are completed prior to hire.	Selected a sample of employees and contractors hired and inspected background checks to determine a criminal background check was performed prior to hire date.	No deviations noted.
	4. For employees and contractors with the ability to write code, specialized training is required annually.	Selected a sample of employees and contractors with the ability to write code and inspected training completions to determine specialized training was completed during the reporting period.	No deviations noted.
1.5	The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.		
	1. A performance appraisal is completed by each employee's manager annually.	Selected a sample of employees and inspected performance appraisals to determine a performance appraisal was performed by the employee's manager during the reporting period.	No deviations noted.
2.0	Common Criteria related to Communication and Information		
2.1	The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.		
	1. As an input of the Risk Assessment, management identifies key systems and system processes to support the in-scope services provided. Relevance, completeness, and accuracy of sources of information necessary to evaluate the operating effectiveness of internal controls and perform internal control activities are included in the Risk Assessment. The controls documented are tied to the risks they have been implemented to mitigate.	Inspected the Risk Assessment to determine it includes the items listed in the control description.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
2.2	The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.		
	1. Employees are required to acknowledge the company's Employee Handbook within 30 days of hire.	Selected a sample of employees hired and inspected acknowledgements to determine Employee Handbook acknowledgments are completed within 30 days of hire.	No deviations noted.
	2. Job descriptions define roles and responsibilities for each position, including the Manager, Governance, Risk, and Compliance who has overall responsibility for all compliance related activities.	Selected a sample of employees, including the Governance Risk and Compliance Manager, and inspected job descriptions to determine job descriptions are defined for each employee selected and the Manager, Governance, Risk, and Compliance has overall responsibility for all compliance related activities.	No deviations noted.
	3. Policy and procedure documents addressing security, availability, confidentiality, and privacy commitments and significant processes are available on the intranet for internal users.	Inspected the intranet to determine policy and procedure documents addressing security, availability, confidentiality and privacy commitments and significant processes are available for all internal users.	No deviations noted.
	4. An organizational chart is in place and available on the intranet for all internal users.	Inspected the intranet to determine the organizational chart is available on the intranet.	No deviations noted.
	5. Senior management communicates results of third-party assessments, internal control monitoring results and vulnerabilities, capacity, and changes that impact the environment, technology, and regulation to the Board of Directors on a quarterly basis.	Selected a sample of quarters and inspected the Board of Directors' meeting minutes to determine the items mentioned in the control description are addressed.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	6. Employees and contractors attend new hire security awareness training and review the Information Security Policies within 30 days of hire. Security awareness and policy review training is held annually. Employees and contractors are required to attend. The Comprehensive Information Security Policy (CISP) is included in security awareness training.	Selected a sample of employees and contractors hired and inspected training transcripts to determine they attended new hire security awareness training within 30 days of hire.	No deviations noted.
		Selected a sample of employees and contractors and inspected training acknowledgements to determine annual training was completed during the reporting period.	No deviations noted.
		Inspected the materials used for new hire security training to determine the CISP was included.	No deviations noted.
2.3	The entity communicates with external parties regarding matters affecting the functioning of internal control.		
	1. The End User Communication Procedure defines the process for informing users of changes, including changes to security, availability, confidentiality, and privacy commitments or practices.	Inspected the End User Communication Procedure to determine it addresses the process for informing users of changes to security, availability, confidentiality, and privacy commitments or practices.	No deviations noted.
	2. New Dealers must sign a Dealer Participation Agreement including, but not limited to, RouteOne data security and confidentiality policies. Included within the Agreement is a Dealer Use Policy describing acceptable use of the RouteOne application.	Selected a sample of new dealers enrolled and inspected signed Dealer Participation Agreements to determine data security, confidentiality, and acceptable use policies are communicated.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	3. New Finance Sources must sign a Finance Source Access and Services Agreement that contains (among other items) confidentiality clauses. In addition to the Agreement, finance sources also receive a Finance Source Use Policy that contains policies regarding acceptable use of the RouteOne application.	Selected a sample of new Finance Sources who have gone "live" and inspected signed Finance Source Access and Service Agreements to determine confidentiality and acceptable use policies are communicated.	No deviations noted.
	4. A Master Services Agreement or contract is used between all other third parties exposed to confidential information through RouteOne. The Agreement contains terms regarding security, confidentiality, and availability.	Selected a sample of new vendors with access to confidential information and inspected their Master Service Agreement to determine the Agreement documents security confidentiality, and availability.	No deviations noted.
	5. Dealers and finance source users that access the RouteOne application must accept the Application Use Policy online before they are able to utilize the system. The policy is displayed on the login page and approval is implied upon logon.	Inspected the login page to determine the acceptable use policy is displayed and accepted upon logon.	No deviations noted.
	6. The RouteOne external-facing website instructs external users on how to report incidents, concerns and complaints.	Inspected the external-facing website to determine it instructs external users how to report incidents, concerns, and complaints.	No deviations noted.
3.0	Common Criteria related to Risk Assessment		
3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.		
	1. The Risk Management Framework documents the system objectives and procedures for managing the Risk Assessment process. Additionally, the Risk Management Framework documents the following processes: identification of assets, threats, impact, probability, risk rating, and risk mitigation.	Inspected the Risk Management Framework to determine the items mentioned in the control description are documented.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
3.2	The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.		
	1. The Risk Assessment is performed annually by the Manager, Governance, Risk, and Compliance and reviewed by members of IT Leadership, GRC Team, and the Legal Team.	Inspected the Risk Assessment to determine it was performed by the Manager, Governance, Risk, and Compliance and reviewed by members of IT Leadership, GRC Team, and the Legal Team during the reporting period.	No deviations noted.
	2. The Risk Assessment documents the risk, risk category, rating, control activities, control type (preventative, detective, automatic, manual), control frequency, and control monitoring. Risks related to segregation of duties, fraud, vendors, technological and environmental changes, and corrective actions are also documented.	Inspected the Risk Assessment to determine it includes the aforementioned controls.	No deviations noted.
3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.		
	1. The Risk Assessment documents the risk, risk category, rating, control activities, control type (preventative, detective, automatic, manual), control frequency, and control monitoring. Risks related to segregation of duties, fraud, vendors, technological and environmental changes, and corrective actions are also documented.	Inspected the Risk Assessment to determine it includes the aforementioned controls.	No deviations noted.
	2. The Anti-Corruption Policy documents the following: •Standards, practices and procedures •Accountability and monitoring •Exceptions and escalation •Incident reporting	Inspected the Anti-Corruption policy to determine it documents the items mentioned in the control description.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.		
	1. The Risk Assessment documents the risk, risk category, rating, control activities, control type (preventative, detective, automatic, manual), control frequency, and control monitoring. Risks related to segregation of duties, fraud, vendors, technological and environmental changes, and corrective actions are also documented.	Inspected the Risk Assessment to determine it includes the aforementioned controls.	No deviations noted.
4.0	Common Criteria related to Monitoring Activities		
4.1	The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.		
	1. Senior management communicates results of third-party assessments, internal control monitoring results and vulnerabilities, capacity, and changes that impact the environment, technology, and regulation to the Board of Directors on a quarterly basis.	Selected a sample of quarters and inspected the Board of Directors' meeting minutes to determine the items mentioned in the control description are addressed.	No deviations noted.
	2. The Internal Audit Procedure documents the scope and frequency of internal control monitoring.	Inspected the Internal Audit Procedure to determine it documents the scope and frequency of internal control monitoring.	No deviations noted.
	3. Security Activity Review meetings with NTT occur on a bi-monthly basis. Remediation of firewall events and vulnerability scans are discussed with the Senior Director of IT Operations and members of the GRC Team.	Selected a sample of months and inspected calendar events and meeting presentations to determine Security Activity Reviews occur with NTT on a bi-monthly basis and remediation items are discussed with the Senior Director of IT Operations and members of the GRC Team.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
4.2	The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.		
	1. Senior management communicates results of third-party assessments, internal control monitoring results and vulnerabilities, capacity, and changes that impact the environment, technology, and regulation to the Board of Directors on a quarterly basis.	Selected a sample of quarters and inspected the Board of Directors' meeting minutes to determine the items mentioned in the control description are addressed.	No deviations noted.
5.0	Common Criteria related to Control Activities		
5.1	The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.		
	1. The Risk Assessment documents the risk, risk category, rating, control activities, control type (preventative, detective, automatic, manual), control frequency, and control monitoring. Risks related to segregation of duties, fraud, vendors, technological and environmental changes, and corrective actions are also documented.	Inspected the Risk Assessment to determine it includes the aforementioned controls.	No deviations noted.
5.2	The entity also selects and develops general control activities over technology to support the achievement of objectives.		
	1. The Risk Assessment documents the risk, risk category, rating, control activities, control type (preventative, detective, automatic, manual), control frequency, and control monitoring. Risks related to segregation of duties, fraud, vendors, technological and environmental changes, and corrective actions are also documented.	Inspected the Risk Assessment to determine it includes the aforementioned controls.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.		
	1. The CISP is available on the intranet to RouteOne employees and contractors and includes policies and procedures regarding: •Appropriate use •Security awareness training •Access rights •Physical control •Confidentiality •Business continuity •Security response •Data disposal and change management •Physical hardware safeguards. The CISP is reviewed and updated by the Governance, Risk, and Compliance (GRC) Team, including the CLPO, at least annually.	Inspected the RouteOne intranet to determine the CISP is available to employees and contractors.	No deviations noted.
		Inspected the CISP to determine the aforementioned policies and procedures are documented.	No deviations noted.
		Inspected the CISP to determine it was reviewed by the GRC Team during the reporting period.	No deviations noted.
	2. The Risk Management Framework documents the system objectives and procedures for managing the Risk Assessment process. Additionally, the Risk Management Framework documents the following processes: identification of assets, threats, impact, probability, risk rating, and risk mitigation.	Inspected the Risk Management Framework to determine the items mentioned in the control description are documented.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	3. The Anti-Corruption Policy documents the following: •Standards, practices and procedures •Accountability and monitoring •Exceptions and escalation •Incident reporting	Inspected the Anti-Corruption policy to determine it documents the items mentioned in the control description.	No deviations noted.
	4. The Internal Audit Procedure documents the scope and frequency of internal control monitoring.	Inspected the Internal Audit Procedure to determine it documents the scope and frequency of internal control monitoring.	No deviations noted.
	5. Retention/disposal standards are documented in the Document Retention Policy.	Inspected the Documentation Retention Policy to determine it outlines the processes for retaining confidential information.	No deviations noted.
	6. The Network Procedure addresses monitoring and responding to security-related events.	Inspected the Network Procedure to determine the process for monitoring and responding to security-related events.	No deviations noted.
	7. The Security Incident Response Procedure (SIRP) addresses the process for identifying, reporting and responding to security, availability, confidentiality, and privacy events and/or incidents.	Performed an observation of the Security Incident Response Procedure with the GRC Team to determine it includes the process for identifying, reporting, and responding to security, availability, confidentiality, and privacy events and/or incidents.	No deviations noted.
6.0	Common Criteria related to Logical and Physical Access Controls		
6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.		
	1. The Manager, Governance, Risk, and Compliance reviews the RouteOne network event logs (such as disabled users, invalid password attempts, etc.) weekly.	Selected a sample of weeks and inspected RouteOne network event log reviews to determine they were reviewed by the Manager, Governance, Risk, and Compliance.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	2. Security Activity Review meetings with NTT occur on a bi-monthly basis. Remediation of firewall events and vulnerability scans are discussed with the Senior Director of IT Operations and members of the GRC Team.	Selected a sample of months and inspected calendar events and meeting presentations to determine Security Activity Reviews occur with NTT on a bi-monthly basis and remediation items are discussed with the Senior Director of IT Operations and members of the GRC Team.	No deviations noted.
	3. A firewall is in place on the RouteOne network. Reports of the production environment firewall events are sent to members of IT Leadership and the GRC Team, who perform the monthly review upon receipt of the report from the service provider.	Inspected the network diagram and the firewall compliance report to determine a firewall is in place.	No deviations noted.
		Selected a sample of months and inspected firewall event reports and email correspondence to determine firewall events reports are sent to members of IT Leadership and the GRC Team for review on a monthly basis.	No deviations noted.
	4. Monthly firewall configuration compliance audits are performed by a third-party on the corporate and production firewalls. Remediations of critical or high findings are resolved by RouteOne through the Change Management process upon receipt of the audit results.	Selected a sample of months and inspected the firewall configuration compliance audit to determine it was performed and findings were remediated, as necessary, upon receipt of audit results.	No deviations noted.
	5. The Asset Tag Procedure documents the role of maintenance of asset inventory. An asset inventory is developed and maintained by the Accounting Department and Network Administrators.	Inspected the Asset Tag Procedure to determine it assigns the role of maintenance of the asset inventory to the Accounting Department and Network Administrators.	No deviations noted.
		Inspected the Asset Inventory to determine it is in place and maintained by the Accounting Department and Network Administrators.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	6. The Data Classification policy documents access based on confidentiality, sensitivity levels, and enforcement.	Inspected the Data Classification Policy to determine it documents access based on confidentiality, sensitivity levels, and enforcement.	No deviations noted.
	7. Administrative-level access to the network is restricted to the IT Operations team. Administrative-level access to the production environment and databases is restricted to those that require access to perform their necessary job functions.	Inspected the system-generated list of network administrators to determine it is restricted to individuals on the IT Operations team.	No deviations noted.
		Inspected the system-generated list of production and database administrators to determine access is restricted to those that require access to perform their necessary job functions.	No deviations noted.
	8. Network authentication parameters include: •minimum password length of 8 characters •password history of 11 passwords •invalid login attempts of 3 attempts •lockout duration after invalid attempts reached of 15 minutes •inactivity timeout of 15 minutes. The in-scope application authentication parameters include: •minimum password length of 8 characters •expiration of 60 days •password history of 5 passwords •invalid login attempts of 3 attempts •inactivity (session) timeout of 30 minutes.	Inspected the network authentication parameters to determine they are set according to the control description.	No deviations noted.
		Inspected the in-scope application authentication parameters to determine they are set according to the control description.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	9. The production, development, and test environments are segregated.	Inspected the network diagram and the environments to determine production, development, and test environments are segregated.	No deviations noted.
	10. The following data is redacted within the RouteOne application: Social Security Numbers (SSN) for the United States; Driver License Numbers; Credit Report Images; Dealer Credit Bureau passwords; and Text Messaging.	Performed an observation of the application database with the Network Administrator to determine the data fields listed in the control description are stored redacted.	No deviations noted.
	11. RSA 2048-bit SSL encryption is used for the browser-based RouteOne application, and 256-bit encryption is used for the database.	Inspected the SSL Certificate to determine RSA 2048-bit encryption is utilized.	No deviations noted.
		Inspected the database encryption settings and the technical white paper to determine 256-bit encryption is used.	No deviations noted.
		Inspected the encryption certificate for the application to determine it is active.	No deviations noted.
	12. A monthly user access review is performed by the GRC Team to ensure access levels to the production databases and the network are appropriate and only authorized individuals have access.	Selected a sample of months and inspected the user access reviews to determine an access rights review for the production databases was performed by the GRC Team.	No deviations noted.
		Selected a sample of months and inspected the user access reviews to determine an access rights review for the network was performed by the GRC Team.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.		
	1. When hired, the HR or hiring manager approves new employees and contractors by entering their information into the Employee Management System (EMS). An automated email is generated from the EMS and is sent to IT to grant access to the network. Access to the production environment is approved by HR or the employee/contractor's manager prior to provisioning.	Selected a sample of employees and contractors hired and inspected their network access email to determine an approval was obtained by HR or the hiring manager through EMS.	No deviations noted.
		Selected a sample of employees and contractors added to production and inspected their production access email to determine an approval was obtained by HR or the employee/contractor's manager prior to provisioning.	No deviations noted.
	2. Access modifications for employees who transfer departments are documented by HR personnel via email and approval is required by the employee's manager.	Selected a sample of employees who transferred departments and inspected tickets to determine access modifications were approved by the employee's manager.	No deviations noted.
	3. HR sends a notification email to the Network Administrator for all employee or contractor terminations. Access is removed or disabled from the network and production by the Network Administrator within one business day of termination.	Selected a sample of employees and contractors terminated and inspected the termination email for each to determine it was sent by HR to the Network Administrator and access removal was performed by the Network Administrator within one business day of termination.	No deviations noted.
		Selected a sample of employees and contractors terminated and inspected system access lists to determine access to the network and production was removed or disabled.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	4. A monthly user access review is performed by the GRC Team to ensure access levels to the production databases and the network are appropriate and only authorized individuals have access.	Selected a sample of months and inspected the user access reviews to determine an access rights review for the production databases was performed by the GRC Team.	No deviations noted.
		Selected a sample of months and inspected the user access reviews to determine an access rights review for the network was performed by the GRC Team.	No deviations noted.
6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.		
	1. A monthly user access review is performed by the GRC Team to ensure access levels to the production databases and the network are appropriate and only authorized individuals have access.	Selected a sample of months and inspected the user access reviews to determine an access rights review for the production databases was performed by the GRC Team.	No deviations noted.
		Selected a sample of months and inspected the user access reviews to determine an access rights review for the network was performed by the GRC Team.	No deviations noted.
	2. A separation of duties policy is in place and reviewed by the CLPO, Director-level counsel, and the Chief Information Officer annually.	Inspected the separation of duties policy to determine it is in place and reviewed by the CLPO, Director-level counsel, and the Chief Information Officer during the reporting period.	No deviations noted.
	3. A matrix documents separation of duties between roles. The matrix is reviewed annually by IT or the GRC Team. The review of the matrix includes a review of current roles' access rights.	Inspected the matrix to determine it documents separation of duties between roles.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Inspected the separation of duties matrix to determine it was reviewed by IT or the GRC Team during the reporting period.	No deviations noted.
6.4	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.		
	The production data is hosted at a third-party location, therefore, physical security of the facility and equipment hosting data is the responsibility of the third-party.		
	1. The main entrance and ancillary entrance doors to the RouteOne building suite are locked at all times and are equipped with proximity badges. The entrances to the server room and the external door are locked at all times and a proximity badge is required for entry.	Observed an employee attempt to gain access to the RouteOne building through its suite entrances to determine they were locked and are equipped with proximity badges.	No deviations noted.
		Observed an employee attempt to gain access to the server room and the external door within the server room entrances to determine they were locked, and a proximity badge is required for entry.	No deviations noted.
	2. Physical access to the building for new employees is approved via an automatic EMS email initiated by HR.	Selected a sample of new badges created and inspected physical access approvals to determine it is approved by HR.	No deviations noted.
	3. Physical access to the building for terminated employees is removed by HR within one business day of termination.	Selected a sample of terminated employees and inspected physical access removals to determine physical access was removed within one business day of termination.	Deviations noted. Physical access was not removed within one business day for one out of 15 sampled terminated employees.
	4. Visitors are required to sign the visitor log.	Performed an observation of the visitor log to determine visitors are required to sign the visitor log.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	5. Access to the server room is restricted to authorized individuals on the GRC, Legal, Facilities, CIO, HR, and IT Operations Teams.	Inspected the system-generated list of users with access to the server room to determine it is restricted to authorized individuals on the GRC, Legal, Facilities, CIO, HR, and IT Operations Teams.	No deviations noted.
	6. Server room access logs are reviewed weekly by the GRC Team.	Selected a sample of weeks and inspected the review of the server room access logs to determine the review was performed by the GRC Team.	No deviations noted.
	7. A video surveillance system monitors the activity inside the server room. The video footage is retained for at least 90 days.	Observed surveillance camera operation to determine cameras are in place.	No deviations noted.
		Inspected security camera footage storage to determine at least 90 days of footage is retained.	No deviations noted.
6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.		
	The production data is hosted at a third-party location, therefore, disposal of the servers is the responsibility of the third -party.		
	1. Retention/disposal standards are documented in the Document Retention Policy.	Inspected the Documentation Retention Policy to determine it outlines the processes for retaining confidential information.	No deviations noted.
	2. A Document Retention Attestation Report is acknowledged by the respective data owners and tracked to completion by the GRC Team on an annual basis to ensure compliance with the retention schedule.	Inspected the Document Retention Attestation Report to determine it was acknowledged by the respective data owners and tracked to completion by the GRC Team during the reporting period.	No deviations noted.
	3. Equipment and media are securely disposed by a third-party on an as needed basis. A certification of destruction is provided upon completion of all asset disposals.	There were no media disposals during the reporting period. Performed corroborative inquiries with the Network and GRC Team to verify there were no media disposals during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	4. A mobile device management system is in place for remote wipe capabilities. All mobile devices are required to be encrypted.	Inspected the mobile device policy settings to determine remote wiping capabilities are in place and devices are required to be encrypted.	No deviations noted.
6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.		
	1. The Manager, Governance, Risk, and Compliance reviews the RouteOne network event logs (such as disabled users, invalid password attempts, etc.) weekly.	Selected a sample of weeks and inspected RouteOne network event log reviews to determine they were reviewed by the Manager, Governance, Risk, and Compliance.	No deviations noted.
	2. Security Activity Review meetings with NTT occur on a bi-monthly basis. Remediation of firewall events and vulnerability scans are discussed with the Senior Director of IT Operations and members of the GRC Team.	Selected a sample of months and inspected calendar events and meeting presentations to determine Security Activity Reviews occur with NTT on a bi-monthly basis and remediation items are discussed with the Senior Director of IT Operations and members of the GRC Team.	No deviations noted.
	3. A firewall is in place on the RouteOne network. Reports of the production environment firewall events are sent to members of IT Leadership and the GRC Team, who perform the monthly review upon receipt of the report from the service provider.	Inspected the network diagram and the firewall compliance report to determine a firewall is in place.	No deviations noted.
		Selected a sample of months and inspected firewall event reports and email correspondence to determine firewall events reports are sent to members of IT Leadership and the GRC Team for review on a monthly basis.	No deviations noted.
	4. Microsoft Defender alerts are submitted to the Security and GRC Teams if new or unknown devices connect to the network. Alerts are responded to by the Security and GRC Teams in real time within the Microsoft Defender Dashboard.	Inspected alert configurations to determine alerts are sent to the Security and GRC Teams if new or unknown devices connect to the network.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Performed an observation with the GRC Team of the Microsoft Defender dashboard and the alert response process to determine alerts are responded to in real time by IT personnel within the Microsoft Defender dashboard.	No deviations noted.
	5. A VPN is in place for remote access to the network and multifactor authentication is required.	Inspected VPN configurations to determine it is in place and multifactor authentication is required.	No deviations noted.
	6. Messages sent both inbound/outbound are checked for digital signatures. Messages sent without a valid digital signature are not accepted by RouteOne and an exception log is generated for errors. These exceptions are also sent to the corresponding inbound/outbound error queue that is monitored by IT Operations and errors are resolved, as necessary.	Inspected the message workflow system settings to determine digital signatures are required for inbound and outbound messages.	No deviations noted.
		Inspected the exception log and performed an observation of the resolution process with the GRC Team to determine alerts are emailed to IT Operations for invalid digital signature errors and errors are resolved, as necessary.	No deviations noted.
6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.		
	1. The following data is redacted within the RouteOne application: Social Security Numbers (SSN) for the United States; Driver License Numbers; Credit Report Images; Dealer Credit Bureau passwords; and Text Messaging.	Performed an observation of the application database with the Network Administrator to determine the data fields listed in the control description are stored redacted.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
2.	Messages sent both inbound/outbound are checked for digital signatures. Messages sent without a valid digital signature are not accepted by RouteOne and an exception log is generated for errors. These exceptions are also sent to the corresponding inbound/outbound error queue that is monitored by IT Operations and errors are resolved, as necessary.	Inspected the message workflow system settings to determine digital signatures are required for inbound and outbound messages.	No deviations noted.
		Inspected the exception log and performed an observation of the resolution process with the GRC Team to determine alerts are emailed to IT Operations for invalid digital signature errors and errors are resolved, as necessary.	No deviations noted.
3.	The GRC Team receives alerts within the Defender dashboard when social security numbers are found in incoming and outgoing emails. The GRC Team then reviews the alerts and performs any responses or actions if necessary.	Inspected the system alert settings and the defender dashboard for emails containing social security numbers to determine the GRC Team receives a notification.	No deviations noted.
		Performed an observation of the alert resolution process to determine the GRC Team addresses the alerts, as necessary.	No deviations noted.
4.	Audits of unauthorized software on workstations and virtual machines are performed twice a month. Findings are reviewed and remediated by the Manager, Governance, Risk, and Compliance.	Selected a sample of months and inspected the unauthorized software audit to determine the Manager, Governance, Risk, and Compliance reviewed and remediated findings from the unauthorized software audit.	No deviations noted.
5.	Write access to unencrypted removable drives is prohibited and enforced through Intune.	Inspected Intune configuration settings to determine write access to removable drives is prohibited.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	6. A mobile device management system is in place for remote wipe capabilities. All mobile devices are required to be encrypted.	Inspected the mobile device policy settings to determine remote wiping capabilities are in place and devices are required to be encrypted.	No deviations noted.
6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.		
	1. Audits of unauthorized software on workstations and virtual machines are performed twice a month. Findings are reviewed and remediated by the Manager, Governance, Risk, and Compliance.	Selected a sample of months and inspected the unauthorized software audit to determine the Manager, Governance, Risk, and Compliance reviewed and remediated findings from the unauthorized software audit.	No deviations noted.
	2. BitLocker encryption is enabled on all laptops and workstations and a unique BitLocker identifier is required to gain access to machines and enforced through Intune.	Inspected the Intune configurations settings to determine BitLocker is enabled, and unique identifiers are required to gain access.	No deviations noted.
	3. Patches to the production servers by NTT are initiated by a Web Hosting Change Management ticket in the RouteOne system. High and medium risk patches are tested, if applicable, and approved by the Senior Director of IT Operations or designee, on behalf of the CIO, prior to implementation in production.	Selected a sample of Web Hosting Change Management tickets initiated and inspected tickets to determine the patches were tested, if applicable, and approved by Senior Director of IT Operations, or designee, on behalf of the CIO prior to implementation in production.	No deviations noted.
	4. Microsoft Defender antivirus is in place for corporate workstations and servers. Definition files are updated every 4 hours and weekly scanning is configured. Real-time scans are also enabled.	Inspected Microsoft Defender settings to determine definition files are updated every 4 hours, weekly scanning is configured, and real-time scans are enabled.	No deviations noted.
	5. Weekly antivirus reviews are performed by the Manager, Governance, Risk, and Compliance or the GRC Analyst.	Selected a sample of weeks and inspected the antivirus review to determine it was performed by the Manager, Governance, Risk, and Compliance or the GRC Analyst.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
7.0	Common Criteria related to System Operations		
7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.		
	1. Security Activity Review meetings with NTT occur on a bi-monthly basis. Remediation of firewall events and vulnerability scans are discussed with the Senior Director of IT Operations and members of the GRC Team.	Selected a sample of months and inspected calendar events and meeting presentations to determine Security Activity Reviews occur with NTT on a bi-monthly basis and remediation items are discussed with the Senior Director of IT Operations and members of the GRC Team.	No deviations noted.
	2. Microsoft Defender alerts are submitted to the Security and GRC Teams if new or unknown devices connect to the network. Alerts are responded to by the Security and GRC Teams in real time within the Microsoft Defender Dashboard.	Inspected alert configurations to determine alerts are sent to the Security and GRC Teams if new or unknown devices connect to the network.	No deviations noted.
		Performed an observation with the GRC Team of the Microsoft Defender dashboard and the alert response process to determine alerts are responded to in real time by IT personnel within the Microsoft Defender dashboard.	No deviations noted.
	3. Patches to the production servers by NTT are initiated by a Web Hosting Change Management ticket in the RouteOne system. High and medium risk patches are tested, if applicable, and approved by the Senior Director of IT Operations or designee, on behalf of the CIO, prior to implementation in production.	Selected a sample of Web Hosting Change Management tickets initiated and inspected tickets to determine the patches were tested, if applicable, and approved by Senior Director of IT Operations, or designee, on behalf of the CIO prior to implementation in production.	No deviations noted.
	4. Reports of the vulnerability scans performed on the production environment by NTT are received and reviewed by the Senior Director of IT Operations, the Security Team, and the GRC Team monthly.	Selected a sample of months and inspected vulnerability scan reports to determine the vulnerability scan reports were reviewed by the Director of IT Operations, the Security Team, and the GRC Team monthly.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	5. Web application scans including the dealer management system are performed by a third-party annually. Findings are prioritized based on management's evaluation of risk and business impact. Medium and above findings are tracked for resolution via Service Desk Tickets.	Inspected the web application scan report and remediation tracker to determine the scan was performed during the reporting period and findings are tracked for resolution by the GRC Team.	No deviations noted.
7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.		
	1. The Manager, Governance, Risk, and Compliance reviews the RouteOne network event logs (such as disabled users, invalid password attempts, etc.) weekly.	Selected a sample of weeks and inspected RouteOne network event log reviews to determine they were reviewed by the Manager, Governance, Risk, and Compliance.	No deviations noted.
	2. Microsoft Defender alerts are submitted to the Security and GRC Teams if new or unknown devices connect to the network. Alerts are responded to by the Security and GRC Teams in real time within the Microsoft Defender Dashboard.	Inspected alert configurations to determine alerts are sent to the Security and GRC Teams if new or unknown devices connect to the network.	No deviations noted.
		Performed an observation with the GRC Team of the Microsoft Defender dashboard and the alert response process to determine alerts are responded to in real time by IT personnel within the Microsoft Defender dashboard.	No deviations noted.
	3. Audits of unauthorized software on workstations and virtual machines are performed twice a month. Findings are reviewed and remediated by the Manager, Governance, Risk, and Compliance.	Selected a sample of months and inspected the unauthorized software audit to determine the Manager, Governance, Risk, and Compliance reviewed and remediated findings from the unauthorized software audit.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	4. Patches to the production servers by NTT are initiated by a Web Hosting Change Management ticket in the RouteOne system. High and medium risk patches are tested, if applicable, and approved by the Senior Director of IT Operations or designee, on behalf of the CIO, prior to implementation in production.	Selected a sample of Web Hosting Change Management tickets initiated and inspected tickets to determine the patches were tested, if applicable, and approved by Senior Director of IT Operations, or designee, on behalf of the CIO prior to implementation in production.	No deviations noted.
	5. The Network Procedure addresses monitoring and responding to security-related events.	Inspected the Network Procedure to determine the process for monitoring and responding to security-related events.	No deviations noted.
7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.		
	1. The Manager, Governance, Risk, and Compliance reviews the RouteOne network event logs (such as disabled users, invalid password attempts, etc.) weekly.	Selected a sample of weeks and inspected RouteOne network event log reviews to determine they were reviewed by the Manager, Governance, Risk, and Compliance.	No deviations noted.
	2. Microsoft Defender alerts are submitted to the Security and GRC Teams if new or unknown devices connect to the network. Alerts are responded to by the Security and GRC Teams in real time within the Microsoft Defender Dashboard.	Inspected alert configurations to determine alerts are sent to the Security and GRC Teams if new or unknown devices connect to the network.	No deviations noted.
		Performed an observation with the GRC Team of the Microsoft Defender dashboard and the alert response process to determine alerts are responded to in real time by IT personnel within the Microsoft Defender dashboard.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	3. The Security Incident Response Procedure (SIRP) addresses the process for identifying, reporting and responding to security, availability, confidentiality, and privacy events and/or incidents.	Performed an observation of the Security Incident Response Procedure with the GRC Team to determine it includes the process for identifying, reporting, and responding to security, availability, confidentiality, and privacy events and/or incidents.	No deviations noted.
7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.		
	1. Security incidents are tracked to resolution and a root cause analysis is performed by IT.	There were no security incidents during the reporting period. Performed corroborative inquiries with the GRC Team to verify there were no security incidents during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.
	2. The RouteOne external-facing website instructs external users on how to report incidents, concerns and complaints.	Inspected the external-facing website to determine it instructs external users how to report incidents, concerns, and complaints.	No deviations noted.
7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.		
	1. Security incidents are tracked to resolution and a root cause analysis is performed by IT.	There were no security incidents during the reporting period. Performed corroborative inquiries with the GRC Team to verify there were no security incidents during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.
	2. The SIRP security incident tabletop walkthrough is performed by RouteOne IT Senior Management and with a third-party annually.	Inspected the results of the SIRP security incident tabletop walkthrough to determine RouteOne IT Senior Management and a third party performed a testing exercise during the reporting period.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
8.0	Common Criteria related to Change Management		
8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.		
	1. The production, development, and test environments are segregated.	Inspected the network diagram and the environments to determine production, development, and test environments are segregated.	No deviations noted.
	2. Patches to the production servers by NTT are initiated by a Web Hosting Change Management ticket in the RouteOne system. High and medium risk patches are tested, if applicable, and approved by the Senior Director of IT Operations or designee, on behalf of the CIO, prior to implementation in production.	Selected a sample of Web Hosting Change Management tickets initiated and inspected tickets to determine the patches were tested, if applicable, and approved by Senior Director of IT Operations, or designee, on behalf of the CIO prior to implementation in production.	No deviations noted.
	3. The Systems Development Life Cycle Procedure (SDLC) outlines the process for development changes.	Inspected the SDLC Procedure to determine it addresses the process of development changes.	No deviations noted.
	4. Releases are deployed on a bi-weekly basis. A Release Risk Analysis spreadsheet is used for each release to track the planned changes that will be included in the release throughout the development process. Probability, impact severity, and an overall risk rating is developed for items within the following categories: Infrastructure, application layers, features, development and testing time, defects, and late changes. The Director of Applications Development, Director of Product Development, Senior Director of IT Operations, and the Canadian Product Director approve the Release Risk Analysis on the production deployment sign off form.	Selected a sample of releases and inspected the Release Risk Analysis spreadsheet to determine the risk analysis was in place to track the planned changes throughout the development process and the items stated in the control description are documented.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Selected a sample of releases and inspected the production deployment form to determine the Director of Applications Development, Director of Product Development, Senior Director of IT Operations, and the Canadian Product Director approved the Release Risk Analysis.	No deviations noted.
	5. Production validation testing is performed by the Test Team no later than five business days after a release has been moved to production.	Selected a sample of releases and inspected tickets to determine production validation testing was performed by the Test Team no later than five business days of being moved into production.	No deviations noted.
	6. Access to the staging environment is restricted to designated members of IT Operations and Production Development teams.	Inspected a system generated list of users with access to the staging environment to determine access is restricted to IT Operations and Production Development teams.	No deviations noted.
	7. Only test data is used in the development and test environments.	Inspected the development and test environments to determine only test data is used in the development and test environments.	No deviations noted.
9.0 Common Criteria related to Risk Mitigation			
9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.		
	1. Cyber insurance is in place and addresses cyber liability in the event of a cybersecurity breach.	Inspected the certificate of liability insurance to determine cyber insurance is in place.	No deviations noted.
	2. The Business Continuity Plan (BCP) is tested annually by the GRC Team. The BCP includes recovery procedures from business disruption, event classifications, internal & external contact lists, cold site acknowledgement, and recovery tasks for each department.	Inspected the BCP to determine the items included in the control description are defined and the BCP was tested by the GRC Team during the reporting period.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
9.2	The entity assesses and manages risks associated with vendors and business partners.		
	1. New Dealers must sign a Dealer Participation Agreement including, but not limited to, RouteOne data security and confidentiality policies. Included within the Agreement is a Dealer Use Policy describing acceptable use of the RouteOne application.	Selected a sample of new dealers enrolled and inspected signed Dealer Participation Agreements to determine data security, confidentiality, and acceptable use policies are communicated.	No deviations noted.
	2. New Finance Sources must sign a Finance Source Access and Services Agreement that contains (among other items) confidentiality clauses. In addition to the Agreement, finance sources also receive a Finance Source Use Policy that contains policies regarding acceptable use of the RouteOne application.	Selected a sample of new Finance Sources who have gone "live" and inspected signed Finance Source Access and Service Agreements to determine confidentiality and acceptable use policies are communicated.	No deviations noted.
	3. A Master Services Agreement or contract is used between all other third parties exposed to confidential information through RouteOne. The Agreement contains terms regarding security, confidentiality, and availability.	Selected a sample of new vendors with access to confidential information and inspected their Master Service Agreement to determine the Agreement documents security confidentiality, and availability.	No deviations noted.
	4. The GRC Team reviews the NTT and Switch SOC reports on an annual basis to determine controls related to physical & environmental security, availability & recovery, on-site privacy & compliance, and security levels and monitoring of the production servers are in place and that system requirements commitments are met.	Inspected the SOC report reviews for NTT and Switch and inquired with the Manager, Governance, Risk, and Compliance to determine the reviews were performed in accordance with the control description by the GRC Team during the reporting period.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
5.	The Vendor Risk Management Policy documents guidelines to analyze and manage risks associated with third-party relationships and also provides guidelines for selecting vendors. It defines the processes for analyzing risk of current vendors as well as monitoring controls, financial condition, quality of service, and the system requirements and responsibilities for risks associated with vendors. It also requires vendor risk assessment, due diligence analysis, and requirements for contracts with new security vendors to determine system commitments and system requirements are met.	Inspected the Vendor Risk Management Policy to determine it is in place as noted in the control description.	No deviations noted.
		Selected a sample of new security vendors to determine vendor risk management procedures were performed during onboarding.	No deviations noted.
6.	Vendor access is removed by IT upon termination	There were no terminated vendors within the reporting period. Inspected the vendor listing and performed an inquiry with the GRC Team to verify there were no vendors terminated within the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.

B. Availability

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
1.0	Additional Criteria for Availability		
1.1	The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.		
	1. Senior management communicates results of third-party assessments, internal control monitoring results and vulnerabilities, capacity, and changes that impact the environment, technology, and regulation to the Board of Directors on a quarterly basis.	Selected a sample of quarters and inspected the Board of Directors' meeting minutes to determine the items mentioned in the control description are addressed.	No deviations noted.
	2. Capacity monitoring of the production data is performed throughout the day by IT via Zabbix. Alerts are configured to be sent to the Network Administrators and resolved as necessary.	Performed an observation of the Zabbix dashboard to determine capacity monitoring is performed throughout the day by IT and alerts are configured to be sent to the Network Administrators and resolved, as necessary.	No deviations noted.
1.2	The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data back-up processes, and recovery infrastructure to meet its objectives.		
	1. The Business Continuity Plan (BCP) is tested annually by the GRC Team. The BCP includes recovery procedures from business disruption, event classifications, internal & external contact lists, cold site acknowledgement, and recovery tasks for each department.	Inspected the BCP to determine the items included in the control description are defined and the BCP was tested by the GRC Team during the reporting period.	No deviations noted.
	2. The Application Disaster Recovery Plan (DRP) for the production environment is prepared and tested annually by IT in conjunction with NTT. The plan includes: recovery teams, response and recovery process, server environment, and testing procedures and maintenance of plan.	Inspected the DRP to determine the items included in the control description are defined and the DRP was tested by IT in conjunction with NTT during the reporting period.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
1.3	The entity tests recovery plan procedures supporting system recovery to meet its objectives.		
	1. The Business Continuity Plan (BCP) is tested annually by the GRC Team. The BCP includes recovery procedures from business disruption, event classifications, internal & external contact lists, cold site acknowledgement, and recovery tasks for each department.	Inspected the BCP to determine the items included in the control description are defined and the BCP was tested by the GRC Team during the reporting period.	No deviations noted.
	2. The Application Disaster Recovery Plan (DRP) for the production environment is prepared and tested annually by IT in conjunction with NTT. The plan includes: recovery teams, response and recovery process, server environment, and testing procedures and maintenance of plan.	Inspected the DRP to determine the items included in the control description are defined and the DRP was tested by IT in conjunction with NTT during the reporting period.	No deviations noted.

C. Confidentiality

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
1.0	Additional Criteria for Confidentiality		
1.1	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.		
	1. The Data Classification policy documents access based on confidentiality, sensitivity levels, and enforcement.	Inspected the Data Classification Policy to determine it documents access based on confidentiality, sensitivity levels, and enforcement.	No deviations noted.
	2. Retention/disposal standards are documented in the Document Retention Policy.	Inspected the Documentation Retention Policy to determine it outlines the processes for retaining confidential information.	No deviations noted.
	3. A Document Retention Attestation Report is acknowledged by the respective data owners and tracked to completion by the GRC Team on an annual basis to ensure compliance with the retention schedule.	Inspected the Document Retention Attestation Report to determine it was acknowledged by the respective data owners and tracked to completion by the GRC Team during the reporting period.	No deviations noted.
	4. Production data is retained according to the Data Purge Policy. Oracle purge jobs of production data are configured to run on a daily basis, except when a release is moved to production.	Inspected the Data Purge Policy to determine procedures for data retention and data purging are defined.	No deviations noted.
		Inspected Oracle purge job schedules to determine production data is purged in accordance with the retention requirements in the Data Purge Policy.	No deviations noted.
1.2	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.		
	1. Retention/disposal standards are documented in the Document Retention Policy.	Inspected the Documentation Retention Policy to determine it outlines the processes for retaining confidential information.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	2. A Document Retention Attestation Report is acknowledged by the respective data owners and tracked to completion by the GRC Team on an annual basis to ensure compliance with the retention schedule.	Inspected the Document Retention Attestation Report to determine it was acknowledged by the respective data owners and tracked to completion by the GRC Team during the reporting period.	No deviations noted.
	3. Equipment and media are securely disposed by a third-party on an as needed basis. A certification of destruction is provided upon completion of all asset disposals.	There were no media disposals during the reporting period. Performed corroborative inquiries with the Network and GRC Team to verify there were no media disposals during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.
	4. Production data is retained according to the Data Purge Policy. Oracle purge jobs of production data are configured to run on a daily basis, except when a release is moved to production.	Inspected the Data Purge Policy to determine procedures for data retention and data purging are defined.	No deviations noted.
		Inspected Oracle purge job schedules to determine production data is purged in accordance with the retention requirements in the Data Purge Policy.	No deviations noted.
	5. Locked shred bins are located throughout the office for corporate data disposal. A third-party securely disposes of the data and a certificate of destruction is documented.	Performed an observation to determine locked shred bins are located throughout the office.	No deviations noted.
		Inspected shredding certificates and performed an inquiry with the GRC Team to determine shredding was completed by the third-party vendor within the reporting period and certificates are retained.	No deviations noted.

D. Privacy

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
1.0	Privacy Criteria related to Notice and Communication		
1.1	The entity provides notice to data subjects about its privacy practices to meet the entity's objectives related to privacy. The notice is updated and communicated to data subjects in a timely manner for changes to the entity's privacy practices, including changes in the use of personal information, to meet the entity's objectives related to privacy.		
	Not applicable. RouteOne does not collect personal information directly from or communicate with data subjects, this is the responsibility of the dealers.		
2.0	Privacy Criteria related to Choice and Consent		
2.1	The entity communicates choices available regarding the collection, use, retention, disclosure, and disposal of personal information to the data subjects and the consequences, if any, of each choice. Explicit consent for the collection, use, retention, disclosure, and disposal of personal information is obtained from data subjects or other authorized persons, if required. Such consent is obtained only for the intended purpose of the information to meet the entity's objectives related to privacy. The entity's basis for determining implicit consent for the collection, use, retention, disclosure, and disposal of personal information is documented.		
	Not applicable. RouteOne does not collect personal information directly from data subjects or communicate directly with the data subjects, this is the responsibility of the dealers.		
3.0	Privacy Criteria related to Collection		
3.1	Personal information is collected consistent with the entity's objectives related to privacy.		
	1. The Privacy Statement on the RouteOne website defines the methods for collecting personal information from data subjects through third parties. Data is not collected directly from data subjects by RouteOne. The Privacy Statement is communicated to potential data subjects through RouteOne's public-facing website.	Inspected the Privacy Statement to determine it defines the methods for collecting personal information.	No deviations noted.
		Inspected the RouteOne external website to determine the Privacy Statement is provided to data subjects.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Performed corroborative inquiries with the GRC Team to determine data subject information is received through third parties and not collected directly from data subjects.	No deviations noted.
3.2	For information requiring explicit consent, the entity communicates the need for such consent, as well as the consequences of a failure to provide consent for the request for personal information, and obtains the consent prior to the collection of the information to meet the entity's objectives related to privacy.		
	Not applicable. RouteOne does not collect personal information directly from data subjects or obtain explicit consent from data subjects; this is the responsibility of the dealers.		
4.0	Privacy Criteria related to Use, Retention, Disposal		
4.1	The entity limits the use of personal information to the purposes identified in the entity's objectives related to privacy.		
1.	When hired, the HR or hiring manager approves new employees and contractors by entering their information into the Employee Management System (EMS). An automated email is generated from the EMS and is sent to IT to grant access to the network. Access to the production environment is approved by HR or the employee/contractor's manager prior to provisioning.	Selected a sample of employees and contractors hired and inspected their network access email to determine an approval was obtained by HR or the hiring manager through EMS.	No deviations noted.
		Selected a sample of employees and contractors added to production and inspected their production access email to determine an approval was obtained by HR or the employee/contractor's manager prior to provisioning.	No deviations noted.
2.	Access modifications for employees who transfer departments are documented by HR personnel via email and approval is required by the employee's manager.	Selected a sample of employees who transferred departments and inspected tickets to determine access modifications were approved by the employee's manager.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	3. HR sends a notification email to the Network Administrator for all employee or contractor terminations. Access is removed or disabled from the network and production by the Network Administrator within one business day of termination.	Selected a sample of employees and contractors terminated and inspected the termination email for each to determine it was sent by HR to the Network Administrator and access removal was performed by the Network Administrator within one business day of termination.	No deviations noted.
		Selected a sample of employees and contractors terminated and inspected system access lists to determine access to the network and production was removed or disabled.	No deviations noted.
	4. A monthly user access review is performed by the GRC Team to ensure access levels to the production databases and the network are appropriate and only authorized individuals have access.	Selected a sample of months and inspected the user access reviews to determine an access rights review for the production databases was performed by the GRC Team.	No deviations noted.
		Selected a sample of months and inspected the user access reviews to determine an access rights review for the network was performed by the GRC Team.	No deviations noted.
	5. The internal Privacy Policy defines the limitations related to the use of personal information collected based on the implicit consent of the data subjects.	Inspected the Privacy Policy to determine it defines the use of personal information collected based on the implicit consent of the data subjects.	No deviations noted.
4.2	The entity retains personal information consistent with the entity's objectives related to privacy.		
	1. A Document Retention Attestation Report is acknowledged by the respective data owners and tracked to completion by the GRC Team on an annual basis to ensure compliance with the retention schedule.	Inspected the Document Retention Attestation Report to determine it was acknowledged by the respective data owners and tracked to completion by the GRC Team during the reporting period.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	2. Production data is retained according to the Data Purge Policy. Oracle purge jobs of production data are configured to run on a daily basis, except when a release is moved to production.	Inspected the Data Purge Policy to determine procedures for data retention and data purging are defined.	No deviations noted.
		Inspected Oracle purge job schedules to determine production data is purged in accordance with the retention requirements in the Data Purge Policy.	No deviations noted.
4.3	The entity securely disposes of personal information to meet the entity's objectives related to privacy.		
	1. A Document Retention Attestation Report is acknowledged by the respective data owners and tracked to completion by the GRC Team on an annual basis to ensure compliance with the retention schedule.	Inspected the Document Retention Attestation Report to determine it was acknowledged by the respective data owners and tracked to completion by the GRC Team during the reporting period.	No deviations noted.
	2. Production data is retained according to the Data Purge Policy. Oracle purge jobs of production data are configured to run on a daily basis, except when a release is moved to production.	Inspected the Data Purge Policy to determine procedures for data retention and data purging are defined.	No deviations noted.
		Inspected Oracle purge job schedules to determine production data is purged in accordance with the retention requirements in the Data Purge Policy.	No deviations noted.
	3. Locked shred bins are located throughout the office for corporate data disposal. A third-party securely disposes of the data and a certificate of destruction is documented.	Performed an observation to determine locked shred bins are located throughout the office.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Inspected shredding certificates and performed an inquiry with the GRC Team to determine shredding was completed by the third-party vendor within the reporting period and certificates are retained.	No deviations noted.
5.0	Privacy Criteria related to Access		
5.1	The entity grants identified and authenticated data subjects the ability to access their stored personal information for review and, upon request, provides physical or electronic copies of that information to data subjects to meet the entity's objectives related to privacy. If access is denied, data subjects are informed of the denial and reason for such denial, as required, to meet the entity's objectives related to privacy.		
	Not applicable. Dealers are responsible for providing the individuals with access to their information and notifying RouteOne of any data changes.		
5.2	The entity corrects, amends, or appends personal information based on information provided by data subjects and communicates such information to third parties, as committed or required, to meet the entity's objectives related to privacy. If a request for correction is denied, data subjects are informed of the denial and reason for such denial to meet the entity's objectives related to privacy.		
	Not applicable. Dealers are responsible for providing the individuals with access to their information and notifying RouteOne of any data changes.		
6.0	Privacy Criteria related to Disclosure and Notification		
6.1	The entity discloses personal information to third parties with the explicit consent of data subjects, and such consent is obtained prior to disclosure to meet the entity's objectives related to privacy.		
	Not applicable. RouteOne does not collect personal information directly from data subjects, this is the responsibility of the dealers. Obtaining explicit consent, if necessary, for authorized disclosures is the responsibility of the dealer.		
6.2	The entity creates and retains a complete, accurate, and timely record of authorized disclosures of personal information to meet the entity's objectives related to privacy.		
	1. Authorized data disclosures from RouteOne to Dealers and Finance Sources are tracked by conversation IDs within the Grafana Dashboard. The dashboard is sent out by the IT Operations team. The database logs transactions of the conversation IDs, which are batched and purged on a daily basis in accordance with the retention requirements in the Data Purge Policy.	Inspected email communication from the IT Operations team and the dashboard to determine conversation IDs are batched and logged in Grafana.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Inspected system settings and for the data purge process to determine production data is purged on a daily basis in accordance with the retention requirements in the Data Purge Policy.	No deviations noted.
6.3	The entity creates and retains a complete, accurate, and timely record of detected or reported unauthorized disclosures (including breaches) of personal information to meet the entity's objectives related to privacy.		
	1. The Legal Department documents and performs corrective actions in response to misuse of personal information by a third-party.	There were no instances of misuse of information by a third party during the reporting period. Performed corroborative inquiries with the CLPO and GRC Team to verify there have been no instances of misuse of information by a third-party during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.
	2. The Legal Department notifies affected users of a breach or incident in the case of a misuse or unauthorized disclosure of personal information.	There were no instances of misuse or unauthorized disclosure of personal information during the reporting period. Performed corroborative inquiries with the CLPO and GRC Team to verify there have been no instances of misuse or unauthorized disclosure of personal information during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.
6.4	The entity obtains privacy commitments from vendors and other third parties who have access to personal information to meet the entity's objectives related to privacy. The entity assesses those parties' compliance on a periodic and as-needed basis and takes corrective action, if necessary.		
	1. A Master Services Agreement or contract is used between all other third parties exposed to confidential information through RouteOne. The Agreement contains terms regarding security, confidentiality, and availability.	Selected a sample of new vendors with access to confidential information and inspected their Master Service Agreement to determine the Agreement documents security confidentiality, and availability.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
	2. The Vendor Risk Management Policy documents guidelines to analyze and manage risks associated with third-party relationships and also provides guidelines for selecting vendors. It defines the processes for analyzing risk of current vendors as well as monitoring controls, financial condition, quality of service, and the system requirements and responsibilities for risks associated with vendors. It also requires vendor risk assessment, due diligence analysis, and requirements for contracts with new security vendors to determine system commitments and system requirements are met.	Inspected the Vendor Risk Management Policy to determine it is in place as noted in the control description.	No deviations noted.
		Selected a sample of new security vendors to determine vendor risk management procedures were performed during onboarding.	No deviations noted.
	3. The internal Privacy Policy states that RouteOne has agreements in place with third parties utilizing collected user information. The Privacy Policy addresses the requirement for an agreement to be in place requiring reasonable safeguards be implemented to comply with law, regulations, and contractual requirements.	Inspected the Privacy Policy to determine it addresses the items listed in the control description.	No deviations noted.
6.5	The entity obtains commitments from vendors and other third parties with access to personal information to notify the entity in the event of actual or suspected unauthorized disclosures of personal information. Such notifications are reported to appropriate personnel and acted on in accordance with established incident response procedures to meet the entity's objectives related to privacy.		
	Not applicable. RouteOne third parties do not have access to personal information.		

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
6.6	The entity provides notification of breaches and incidents to affected data subjects, regulators, and others to meet the entity's objectives related to privacy.		
	1. The Legal Department notifies affected users of a breach or incident in the case of a misuse or unauthorized disclosure of personal information.	There were no instances of misuse or unauthorized disclosure of personal information during the reporting period. Performed corroborative inquiries with the CLPO and GRC Team to verify there have been no instances of misuse or unauthorized disclosure of personal information during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.
6.7	The entity provides data subjects with an accounting of the personal information held and disclosure of the data subjects' personal information, upon the data subjects' request, to meet the entity's objective related to privacy.		
	Not applicable. RouteOne is not responsible for providing an account to data subjects of personal information held and disclosed; this is the responsibility of the dealers.		
7.0	Privacy Criteria related to Quality		
7.1	The entity collects and maintains accurate, up-to-date, complete, and relevant personal information to meet the entity's objectives related to privacy.		
	Data Collection is the responsibility of the dealers and financial sources. Access to the information is restricted via logical access procedures for granting, modifying, and removing access.		
	1. When hired, the HR or hiring manager approves new employees and contractors by entering their information into the Employee Management System (EMS). An automated email is generated from the EMS and is sent to IT to grant access to the network. Access to the production environment is approved by HR or the employee/contractor's manager prior to provisioning.	Selected a sample of employees and contractors hired and inspected their network access email to determine an approval was obtained by HR or the hiring manager through EMS.	No deviations noted.

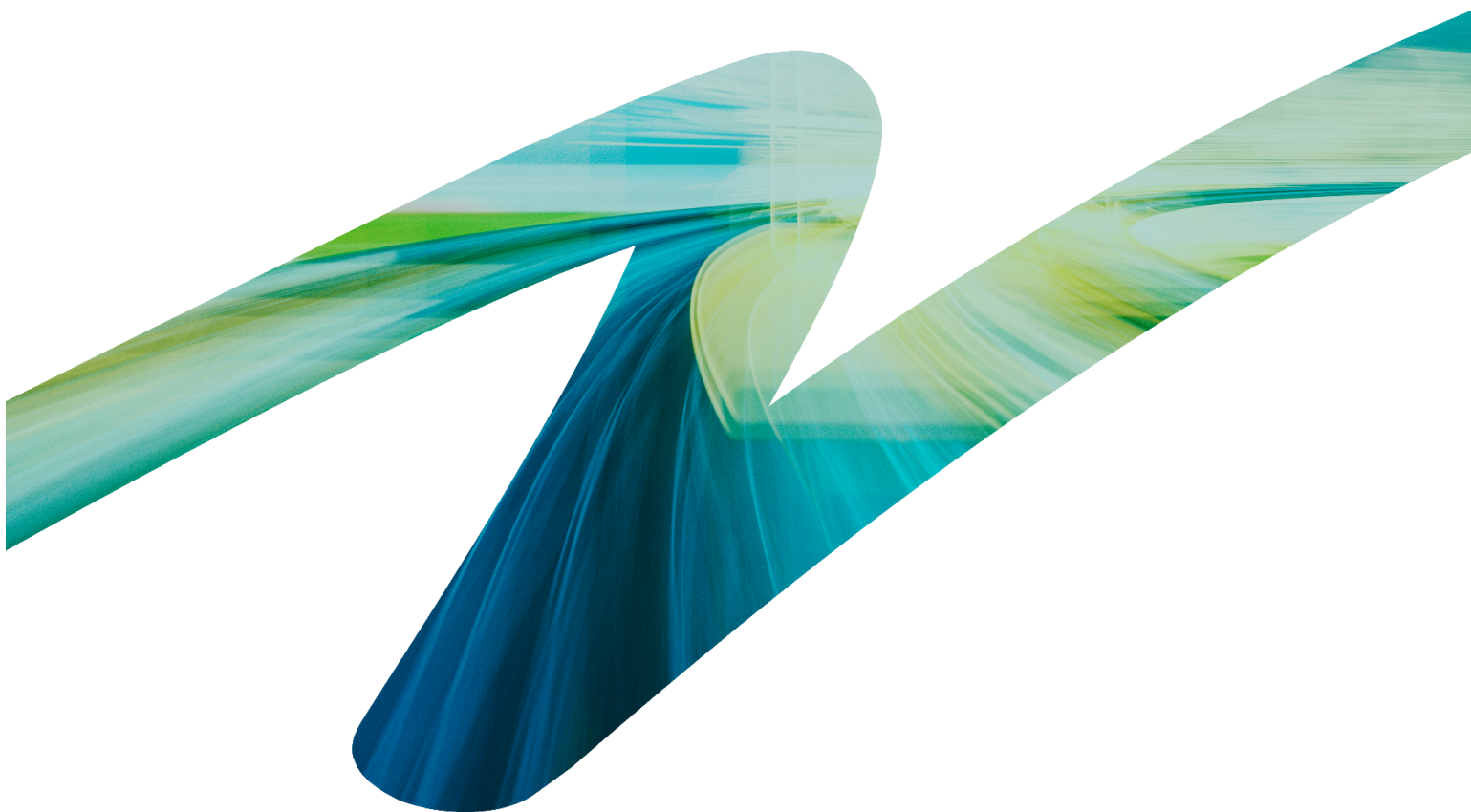
Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
		Selected a sample of employees and contractors added to production and inspected their production access email to determine an approval was obtained by HR or the employee/contractor's manager prior to provisioning.	No deviations noted.
	2. Access modifications for employees who transfer departments are documented by HR personnel via email and approval is required by the employee's manager.	Selected a sample of employees who transferred departments and inspected tickets to determine access modifications were approved by the employee's manager.	No deviations noted.
	3. HR sends a notification email to the Network Administrator for all employee or contractor terminations. Access is removed or disabled from the network and production by the Network Administrator within one business day of termination.	Selected a sample of employees and contractors terminated and inspected the termination email for each to determine it was sent by HR to the Network Administrator and access removal was performed by the Network Administrator within one business day of termination.	No deviations noted.
		Selected a sample of employees and contractors terminated and inspected system access lists to determine access to the network and production was removed or disabled.	No deviations noted.
	4. A monthly user access review is performed by the GRC Team to ensure access levels to the production databases and the network are appropriate and only authorized individuals have access.	Selected a sample of months and inspected the user access reviews to determine an access rights review for the production databases was performed by the GRC Team.	No deviations noted.
		Selected a sample of months and inspected the user access reviews to determine an access rights review for the network was performed by the GRC Team.	No deviations noted.

Criteria	Controls Specified by RouteOne	Testing Performed by Service Auditor	Results of Tests
8.0	Privacy Criteria related to Monitoring and Enforcement		
8.1	The entity implements a process for receiving, addressing, resolving, and communicating the resolution of inquiries, complaints, and disputes from data subjects and others and periodically monitors compliance to meet the entity's objectives related to privacy. Corrections and other necessary actions related to identified deficiencies are made or taken in a timely manner.		
	Communication with data subjects is the responsibility of the dealers.		
	1. Senior management communicates results of third-party assessments, internal control monitoring results and vulnerabilities, capacity, and changes that impact the environment, technology, and regulation to the Board of Directors on a quarterly basis.	Selected a sample of quarters and inspected the Board of Directors' meeting minutes to determine the items mentioned in the control description are addressed.	No deviations noted.
	2. The Business Operations Customer Communications document outlines the processes for handling customer inquiries, complaints, and disputes.	Inspected the Business Operations Customer Communications document to determine it addresses the processes for handling customer inquiries, complaints, and disputes.	No deviations noted.
	3. RouteOne has implemented a dispute resolution documentation in order to effectively track each individual complaint along with the resolution and the communication to the RouteOne customers.	There were no instances of customer disputes during the reporting period. Inspected the compliance inbox to verify there were no instances of customer disputes during the reporting period.	There was no circumstance that warranted the performance of the control. Accordingly, no testing was performed by us.

SECTION 5. OTHER INFORMATION PROVIDED BY MANAGEMENT OF ROUTEONE, LLC

The section below provides RouteOne's management response to deviations noted in Section 4. This information has been provided by management, and has not been subjected to examination procedures by Plante Moran.

Control Activity	Deviation	Management Response
Physical Access Removal	Physical access was not removed within one business day for one out of 15 sampled terminated employees.	The affected employee's RouteOne corporate office badge access was disabled 10 days after termination. The employee's badge did not grant access to privileged areas within the RouteOne offices, including the corporate server room or HR/Legal records rooms. The employee's badge access logs were reviewed following termination, and it was confirmed that the employee had not entered or attempted to enter the office since 2020. Process enhancements, including automatic task tracking for physical access removal, have been implemented and are actively monitored by the GRC Team.



For more information regarding the report, contact:

Dan Doman | Chief Legal and Privacy Officer
RouteOne, LLC
248.862.7083
Ddoman@routeone.com

For more information on Plante Moran, contact:

Natalie Pintar | Partner
Plante Moran
248.223.3369
Natalie.Pintar@plantemoran.com